

COMPLETE STUDY NOTES
EXAM | LABS | CHEAT SHEETS | PRACTICE



LEARN
PRACTICE
CERTIFY
GROW

SC-500

MICROSOFT CERTIFIED

Cloud and AI Security Engineer Associate

Exam SC-500 • Complete A to Z Study Notes

Implementing End-to-End Security Controls for
Cloud and AI Workloads

Covers all four skill domains, every bullet in the official
"skills measured" list, comparison tables, least-privilege
role cheat-sheets, exam traps, and a final-week plan.

SECURE
SCALABLE
RESPONSIBLE
AI FOR A
BRIGHTER
TOMORROW

*Learn
Build
Secure
Grow*



Microsoft Azure
CLOUD SECURITY



Microsoft Entra ID
IDENTITY & ACCESS



Microsoft Defender
THREAT PROTECTION



Microsoft Sentinel
DETECTION & RESPONSE



Security Copilot
AI SECURITY

Table of Contents

How to use these notes	6
Reading strategy	6
Exam facts	7
Skill domains and weights	8
What changed: AZ-500 → SC-500	8
The exam mindset	9
1.1 Secure access with Microsoft Entra ID	10
Privileged Identity Management (PIM)	10
Conditional Access (CA)	11
Authentication methods: MFA and passwordless	12
Identity for applications: app registrations vs enterprise applications	13
OAuth permission grants and consent settings	13
Managed identities for Azure resources	14
1.2 Secure secrets and keys with Azure Key Vault	16
Deploy and configure	16
Control plane vs data plane (frequently tested)	16
Firewall settings on Key Vault	17
Manage keys, secrets, and certificates	17
Defender for Key Vault and secret scanning	18
1.3 Governance: enforce security and regulatory compliance	19
Azure Policy	19
Effects (memorize the differences)	19
Defender for Cloud: standards, recommendations, and regulatory compliance	20
Resource locks	21
RBAC: built-in roles, custom roles, overprivileged access	21
Evaluate and remediate overprivileged assignments	22
Azure Backup security features	23
Security controls with infrastructure as code (IaC)	23
2.1 Implement security for storage accounts	24
Authorization options (strongest → weakest)	24
Encryption and data protection	25
Azure Storage firewall rules	25
Microsoft Defender for Storage	26
2.2 Implement security for databases (Azure SQL)	27
Platform-level security in Azure SQL	27
Auditing for Azure SQL Database and SQL Managed Instance	27
Defender for Databases	28
2.3 Implement security for Azure network services	29
Network security groups (NSGs) and application security groups (ASGs)	29



Azure Virtual Network Manager (AVNM)	29
Azure Virtual WAN security	30
VPN connection security	30
Microsoft Entra Private Access	31
Private endpoints and Private Link	31
Private Link service (expose your own service privately)	32
Azure Firewall	32
Evaluate effective security rules with Network Watcher diagnostics	33
Related topics that can still appear	34
DDoS Protection tiers	34
Web front-doors	34
3.1 Implement security for AI	35
The big picture: what can go wrong with AI	35
Identify overexposure of data in SharePoint	35
Purview DSPM: risks from Microsoft Copilot and AI apps	36
Real-time protection for Microsoft Copilot Studio agents	36
Microsoft Entra Agent ID	37
Analyze blast radius with Defender XDR	37
AI Gateway in Azure API Management for Microsoft Foundry	37
Defender for AI Services (Cloud Workload Protection)	38
Guardrails for agent security in Microsoft Foundry	38
Data and AI security dashboard (Defender for Cloud)	39
Manage agents in the Microsoft 365 admin center (Agent 365)	39
3.2 Implement security for servers and virtual machines	40
Disk encryption	40
Trusted launch security features (secure boot, vTPM, integrity monitoring, security type)	40
Azure Bastion	41
NSG rules for the AzureBastionSubnet (seen on beta exam reports)	41
Just-in-time (JIT) VM access	41
Azure Arc and hybrid/multicloud servers	42
Defender for Servers (Defender for Cloud)	42
Vulnerability scanning and EDR	43
Agentless scanning	43
Azure Machine Configuration	43
3.3 Implement security for application platform services	45
Defender for Containers	45
Azure Kubernetes Service (AKS)	45
Azure Container Registry (ACR), ACI, and Container Apps	46
Azure Functions	46
Azure Logic Apps	46



Azure App Service.....	47
Azure Web Application Firewall (WAF)	47
Back-end API protection with API Management.....	48
4.1 Manage security posture with Microsoft Defender for Cloud	49
Defender CSPM: identify security risks.....	49
Evaluate compliance against security frameworks	50
Enable and configure workload protection plans	50
Connect hybrid and multicloud (AWS and GCP).....	50
Microsoft Defender Vulnerability Management (MDVM) settings for Azure VMs	51
Microsoft Defender External Attack Surface Management (EASM).....	51
4.2 Implement activity and event collection in Microsoft Sentinel	53
Workspaces and roles	53
Content hub	53
Data connectors: Microsoft services and Azure resources	54
Syslog and Common Event Format (CEF).....	54
Windows Security events, DCRs, and Windows Event Forwarding (WEF)	54
Custom log tables, retention, and data lake	55
Automation rules and playbooks.....	55
Query Microsoft Purview Audit in Defender XDR	56
4.3 Implement Microsoft Security Copilot.....	57
What it is.....	57
Configure workspaces (capacity, SCUs, data residency)	57
Permissions and roles.....	57
Plugins.....	58
Agents: Microsoft agents and Security Store agents	58
5.1 Scenario → best answer map.....	59
5.2 Least-privilege role picker	62
5.3 Numbers and defaults to memorise	63
5.4 Top exam traps (read these the night before).....	64
5.5 Final-week plan (7 days).....	65
5.6 Verify these before exam day	66
5.7 Resources and labs	66
Learning paths in SC-500T00 (by domain)	67



MICROSOFT CERTIFIED

Cloud and AI Security Engineer Associate

Exam SC-500 · Complete A to Z Study Notes

Implementing End-to-End Security Controls for Cloud and AI Workloads

Covers all four skill domains, every bullet in the official “skills measured” list, comparison tables, least-privilege role cheat-sheets, exam traps, and a final-week plan.

Skills measured are current as of the Microsoft Learn study guide (last updated 13 May 2026; page refreshed 31 Jul 2026). Notes compiled 21 September 2026.

Coloured callout boxes flag exam traps, memory tricks, and what is new versus AZ-500 — everything is in English throughout.



How to use these notes

These notes are built to cover every bullet in Microsoft's official **skills measured** list. There are four domains; within each domain, topics generally follow: **What it is** → **How it works** → **Key settings** → **Exam traps**.

Colour boxes: red = exam trap, green = memory trick, purple = new in SC-500 (not in AZ-500).

Part	Content	Exam weight
0	Exam snapshot, AZ-500 vs SC-500 changes, mindset	—
1	Manage identity, access, and governance — Entra ID (PIM, Conditional Access, auth methods, app identities, consent, managed identities), Key Vault, Azure Policy, Defender for Cloud governance, locks, RBAC, Backup security, IaC	20–25%
2	Secure storage, databases, and networking — Storage accounts, Azure SQL, NSG/ASG, AVNM, Virtual WAN, VPN, Entra Private Access, Private Endpoint/Link, Azure Firewall, Network Watcher (+ DDoS/WAF related)	25–30%
3	Secure compute — AI security (Copilot, Entra Agent ID, Foundry, AI Gateway, Defender for AI), servers & VMs, containers, Functions, Logic Apps, App Service, WAF, API Management	20–25%
4	Manage and monitor security posture — Defender for Cloud (CSPM, multicloud, EASM, MDVM), Microsoft Sentinel, Security Copilot	20–25%
5	Cheat sheets: X-vs-Y tables, least-privilege role picker, top exam traps, final-week plan, labs & resources	—

Reading strategy

- **First pass:** read Part 0 and skim each domain's tables and coloured boxes.
- **Second pass:** do the hands-on labs (Part 5) while reading the matching section — the exam is implementation-focused, so “which setting/role/feature do I pick?” matters more than definitions.
- **Final pass:** Part 5 only (comparison tables, role picker, traps).



PART 0

Exam snapshot

Format, weights, what changed from AZ-500

Exam facts

Item	Detail
Exam / certification	SC-500: Implementing End-to-End Security Controls for Cloud and AI Workloads → Microsoft Certified: Cloud and AI Security Engineer Associate
Replaces	AZ-500 (Azure Security Engineer Associate). AZ-500, the certification and its renewal assessments retired on 31 August 2026 — you can no longer earn or renew it.
Passing score	700 / 1000
Time	120 minutes of exam time (appointment slot about 150 min including NDA and surveys). If the exam is not localized to your language you can request +30 min.
Question types (beta report)	Around 59 questions in one reported beta sitting: standalone MCQ, drag-and-drop , and case studies with True/False items. No labs were reported in beta — but Microsoft can add performance tasks later, so do not be surprised.
Open book	Reported: Microsoft Learn documentation is available during the exam (role-based exam policy). It is a safety net only — about 2 minutes per question leaves no time to look everything up.
Status	Beta ran from May 2026; generally available since late July 2026 , so results are now scored immediately (pass/fail shown at the end).
Practice assessment	The Microsoft Learn practice assessment was not yet published at the time of the last check. Microsoft says these normally appear within about 8 weeks of GA — re-check the exam page. Use the exam sandbox to see the question UI.
Scheduling	Pearson VUE via the Learn exam page. Register with a personal Microsoft account , not a work/school account, so your transcript survives job changes.
Validity	Associate certifications last 12 months; renew for free through the online renewal assessment on Microsoft Learn.
Audience / prerequisites	No formal prerequisite, but Microsoft expects practical Azure + hybrid administration (compute, network, storage), strong Microsoft Entra ID familiarity, and familiarity with Microsoft 365 administration. Intermediate-to-advanced.



Skill domains and weights

Domain	Weight	Approx. questions*	Big-ticket topics
1. Manage identity, access, and governance	20–25%	12–15	PIM, Conditional Access, consent, managed identity, Key Vault, Azure Policy, RBAC, locks, backup security
2. Secure storage, databases, and networking	25–30%	15–18	Storage firewall/SAS, Azure SQL, NSG/ASG, AVNM, Firewall, Private Endpoint, VPN, Virtual WAN
3. Secure compute	20–25%	12–15	AI security (new), Bastion/JIT, Defender for Servers, AKS/ACR, App Service, WAF, APIM
4. Manage and monitor security posture	20–25%	12–15	Defender CSPM, multicloud, Sentinel data collection, Security Copilot

*Estimate assuming roughly 59 scored questions; the real number varies.

What changed: AZ-500 → SC-500

SC-500 is **not a renamed AZ-500**. It keeps the identity/network/storage/Defender-for-Cloud/Sentinel core and adds a full AI-security discipline plus more posture-management depth.

Area	New or expanded in SC-500
AI security (Domain 3)	Copilot & AI-app risk with Purview DSPM , overshared SharePoint data, Copilot Studio real-time agent protection, Microsoft Entra Agent ID (Conditional Access, access management, blast radius in Defender XDR), AI Gateway in API Management for Microsoft Foundry , Defender for AI Services , Foundry guardrails , Data and AI security dashboard , agent management in the Microsoft 365 admin center (Agent 365)
Identity	OAuth permission grants & consent settings called out explicitly; managed identities; authentication methods incl. passwordless; PIM
Governance	Azure Backup security features (MUA/Resource Guard, immutability, enhanced soft delete); infrastructure-as-code security controls; overprivileged access remediation
Networking	Azure Virtual Network Manager , Virtual WAN security (secured hub), Microsoft Entra Private Access , Network Watcher diagnostics
Compute	Azure Machine Configuration , Azure Arc for hybrid/multicloud servers, agentless scanning , trusted launch (secure boot, vTPM, integrity monitoring), Container Apps/ACI, Logic Apps
Posture	Defender CSPM (attack paths, Cloud Security Explorer, secret scanning), AWS/GCP connectors, Defender EASM , Defender Vulnerability Management



Area	New or expanded in SC-500
Monitoring	Sentinel: AMA-based collection (Windows events, WEF, Syslog, CEF), custom log tables, retention, Purview Audit in Defender XDR ; Security Copilot (workspaces, roles, plugins, Microsoft and Security Store agents)

NEW IN SC-500 (not in AZ-500)

Beta-exam feedback (an MVP who sat the beta on 8 Jun 2026) said the exam was **harder than AZ-500**, paragraph-style, and that **Azure networking**, **least-privilege role selection**, and **Security Copilot** appeared more than expected. Treat that as one data point, not a guarantee.

The exam mindset

MEMORY TRICK / TIP

Think like a cloud & AI security engineer: **enforce least privilege → reduce exposure → protect secrets → secure workloads → monitor posture → respond with automation**. When two answers both “work”, pick the one that is **more restrictive, more automated, and lower-maintenance** (managed identity over secrets, private endpoint over public, RBAC over access keys).



DOMAIN 1 · 20–25%

Manage identity, access, and governance

Entra ID · Key Vault · Azure Policy · RBAC · Defender for Cloud governance · Backup security · IaC

1.1 Secure access with Microsoft Entra ID

Privileged Identity Management (PIM)

PIM provides **just-in-time (JIT)**, **time-bound**, **approval-based** privileged access. It covers **Microsoft Entra roles**, **Azure resource roles** (subscription/RG/resource), and **PIM for Groups**. Requires Entra ID P2 / ID Governance licensing.

Concept	Meaning
Eligible assignment	User <i>can</i> activate the role, but has no privilege until they do. Default recommendation for admins.
Active assignment	Privilege is in effect now. Can be time-bound (start/end) or permanent.
Activation	Eligible → active for a limited duration. Configurable requirements: MFA, justification, ticket info, approval (approvers), optional Conditional Access authentication context . Maximum activation duration is configurable (default 8 hours).
Role settings	Per role: max activation duration, require MFA/justification/approval, notification emails, allow permanent eligible/active, expiry of assignments.
Access reviews	Recurring reviews of privileged assignments (Entra ID Governance). Reviewers can remove stale access.
Alerts	PIM flags roles assigned outside PIM, too many Global Admins, roles not used, stale accounts, etc.
Break-glass (emergency access) accounts	2 cloud-only accounts, permanent Global Admin, excluded from Conditional Access policies that could lock everyone out, strong phishing-resistant credential stored offline, alerts on sign-in. They are <i>not</i> PIM-eligible (you need them when PIM/MFA is broken).



EXAM TRAP

“Reduce standing privilege / JIT for Azure roles” → **PIM eligible assignments** (not just RBAC assignment).

PIM controls **who can activate**; it does not replace Conditional Access. Use an **authentication context** to force stronger auth on activation.

Approval flow: eligible user requests → **approver** approves → role active for the time window. Approvers themselves need not hold the role.

Conditional Access (CA)

CA is Entra’s **policy engine (if-then)**: *If* signals match → *Then* apply access controls. Evaluated **after first-factor authentication**. All matching policies apply; **any Block wins**; grant controls from multiple policies are combined (AND across policies).

Building block	Options
Assignments – users/agents	Users, groups, roles, guests/external users, workload identities , agent identities (Entra Agent ID) ; include/exclude.
Target resources	Cloud apps (e.g. Azure management, Office 365), user actions (register security info), authentication context , agent resources.
Conditions	User risk, sign-in risk (Identity Protection, P2), device platform, locations (named locations, countries, trusted IPs), client apps, filter for devices , authentication flows.
Grant controls	Block · Require MFA · Require authentication strength · Require compliant device · Require Microsoft Entra hybrid joined · Approved client app / app protection policy · Require password change (for user risk) · Terms of use. Multiple controls: <i>require all or require one</i> .
Session controls	Sign-in frequency · Persistent browser session · App-enforced restrictions · Conditional Access App Control (Defender for Cloud Apps) · Continuous Access Evaluation (CAE) · Token protection · Disable resilience defaults.
Testing tools	Report-only mode · What If tool · Sign-in logs → Conditional Access tab · CA insights workbook.

Authentication strength (built-in)	Includes
Multifactor authentication	Passwordless & phishing-resistant methods + password + a second factor (Authenticator push/OATH etc.).
Passwordless MFA	Authenticator passwordless, passkeys/FIDO2, Windows Hello for Business, certificate-based auth.



Authentication strength (built-in)	Includes
Phishing-resistant MFA	FIDO2/passkeys, Windows Hello for Business, certificate-based auth (multi-factor). Strongest — required for admins in high-security answers.

EXAM TRAP

Security defaults vs Conditional Access: Security defaults are the free, all-or-nothing baseline; you must **turn them off** to use custom CA policies.

Report-only first. Before enforcing a policy that might lock people out → deploy in report-only, review sign-in logs / What If, then enable.

Risk-based policies (sign-in risk / user risk) need **Entra ID P2**. Workload-identity CA needs **Workload ID Premium** and only applies to **single-tenant service principals**.

CA does **not** apply to break-glass accounts if you excluded them — that is intended; monitor their sign-ins.

CAE revokes access near-real-time on events like account disable, password change, location change; token protection binds tokens to the device.

Authentication methods: MFA and passwordless

Method	Notes
Microsoft Authenticator (push)	Number matching + additional context are on by default. Also supports phone sign-in (passwordless) .
Passkeys / FIDO2 security keys	Phishing-resistant, hardware- or device-bound. Configure key restrictions/AAGUIDs and attestation in the policy.
Windows Hello for Business	Phishing-resistant, device-bound PIN/biometric backed by TPM.
Certificate-based authentication (CBA)	Entra-native X.509 auth, single or multi-factor binding; phishing-resistant when multifactor.
OATH software/hardware tokens (TOTP)	Codes; acceptable MFA but not phishing-resistant.
SMS / voice	Weakest — usable for MFA/SSPR but avoid for admins.
Temporary Access Pass (TAP)	Time-limited passcode to bootstrap passwordless registration or recover a lost credential.
Email OTP, security questions	SSPR-only style methods (security questions not for MFA).

- **Authentication methods policy** is the central place to enable methods per group. It supersedes the legacy per-user MFA and legacy SSPR method settings — avoid **per-user MFA**.



- **Password protection:** global + custom **banned password list**, **smart logout** (protects against password spray), on-prem AD DS integration with the agent.
- **SSPR** needs registered methods; combine with **combined security info registration** and target registration with a CA policy on the user action “Register security information”.
- Passwordless progression: password + MFA → **passwordless (Authenticator)** → **phishing-resistant (FIDO2/passkey, WHfB, CBA)**.

Identity for applications: app registrations vs enterprise applications

	App registration	Enterprise application
What	The application object — the global definition (in its home tenant).	The service principal — the local instance/identity of the app in each tenant .
Holds	Redirect URIs, API permissions requested, secrets/certificates/ federated credentials , app roles, manifest.	Assignment (users/groups), SSO config, provisioning, consent grants, CA targeting, sign-in logs.
Who uses	Developers / app owners.	Tenant admins manage access to the app.
Created	Manually (Portal → App registrations).	Automatically when app is registered, consented to, or a gallery app is added.

- **Credentials, best → worst:** managed identity (no credential) → **federated credential / workload identity federation** (no secret) → **certificate** → client secret (short-lived, rotate).
- **Single-tenant vs multi-tenant** app: single-tenant only for your directory (safer default).
- **Assignment required?** on the enterprise app + assign users/groups to restrict who can sign in. Combine with CA.
- Enterprise-app roles: **Application Administrator** and **Cloud Application Administrator** manage app registrations/enterprise apps (Cloud App Admin cannot manage Application Proxy). **Application Developer** can register apps if allowed.

OAuth permission grants and consent settings

Permission type	Meaning	Consent
Delegated	App acts on behalf of a signed-in user ; effective access = intersection of user rights and the scope.	User consent (low-impact) or admin consent.
Application (app roles)	App acts as itself, no user (daemon/background); often very powerful (e.g. <i>Mail.Read</i> on all mailboxes).	Always admin consent.



- **User consent settings** (Entra → Enterprise apps → Consent and permissions): (1) *Do not allow user consent*; (2) **Allow user consent for apps from verified publishers, for selected (low-impact) permissions** — the Microsoft-recommended setting; (3) *Allow user consent for all apps* (risky, enables consent phishing). Also **app consent policies** for custom rules.
- **Admin consent workflow**: users request → designated **reviewers** approve/deny, so users are not stuck.
- **Review and revoke**: Enterprise apps → *Permissions* → review; revoke tenant-wide (admin) or per-user grants (Graph `oauth2PermissionGrants`, PowerShell/Graph). Disable the service principal to block sign-in immediately.
- **Illicit consent grant (consent phishing)**: attacker app tricks a user into granting Mail/Files scopes. Mitigation = restrict user consent, verified publishers, admin consent workflow, monitor consent events in audit log / Defender for Cloud Apps app governance.
- Who can grant tenant-wide admin consent: **Global Administrator** or **Privileged Role Administrator**; **Application Administrator / Cloud Application Administrator** can consent to delegated + application permissions **except Microsoft Graph app roles**.

EXAM TRAP

Question: “Users are granting broad Graph permissions to unknown apps” → change user consent to **verified publishers + low-impact permissions only**, enable the **admin consent workflow**, then review/revoke risky grants. Not “disable all apps”.

Managed identities for Azure resources

	System-assigned	User-assigned
Lifecycle	Tied to one resource; deleted with it.	Standalone Azure resource; lifecycle independent.
Sharing	1 : 1 (that resource only).	One identity can be attached to many resources; a resource can have several.
Best for	Simple single-resource workload.	Shared access pattern, pre-provisioned RBAC, re-creatable resources, avoiding RBAC propagation delay at deployment.
Notes	Also created for Arc-enabled servers.	Also used as AKS kubelet/control-plane identities, and with federated credentials.

- No credentials to store or rotate. The workload gets tokens from the **Instance Metadata Service (IMDS)** (169.254.169.254) or the platform (App Service `IDENTITY_ENDPOINT`).



- Grant access with **Azure RBAC** on the target (e.g. *Key Vault Secrets User*, *Storage Blob Data Reader*) or Entra/Graph permissions.
- “Eliminate secrets in app config” → **managed identity + Key Vault/RBAC**, or Key Vault references.



1.2 Secure secrets and keys with Azure Key Vault

Deploy and configure

Option	Details
Vault vs Managed HSM	Key Vault (Standard = software-protected keys; Premium = HSM-backed keys). Managed HSM = single-tenant, FIPS-validated HSM pool with its own local RBAC, for the strictest key control.
Objects	Keys (RSA/EC, HSM or software), secrets (any string ≤ 25 KB), certificates (with lifecycle/renewal).
Soft delete	Always on; retention 7–90 days (set at creation, cannot be disabled).
Purge protection	Optional but irreversible once on . Blocks permanent deletion until the retention period ends. Required for customer-managed keys used by Storage, Disk Encryption Sets, SQL TDE, etc.
Permission model	Azure RBAC (recommended) vs legacy vault access policy . Only one model is active per vault; switching changes how existing access is evaluated.
Diagnostics	Enable AuditEvent diagnostic logs to Log Analytics / Storage / Event Hubs; alert on failures & anomalies.

Control plane vs data plane (frequently tested)

Plane	What it does	Typical roles
Control plane (management, ARM)	Create/delete vault, set network rules, access policies (legacy), tags, diagnostic settings.	Owner, Contributor, Key Vault Contributor (manages vaults but cannot read secrets/keys), User Access Administrator.
Data plane	Read/write/sign/wrap keys, secrets, certificates.	Key Vault Administrator (all data ops), Secrets Officer/User , Crypto Officer/User , Certificates Officer , Reader (metadata only), Crypto Service Encryption User (wrap/unwrap for CMK), Data Access Administrator (assign KV data roles with restrictions), Purge Operator .



EXAM TRAP

Contributor / Key Vault Contributor cannot read secrets when the vault uses the RBAC model (control plane only). To let an app read secrets → **Key Vault Secrets User** on the vault (or the specific secret).

Under the *access policy* model a Contributor on the vault could edit access policies and grant themselves data access — one reason RBAC is preferred.

Least privilege for an app that only decrypts: **Key Vault Crypto User**; for CMK on Storage: **Key Vault Crypto Service Encryption User** to the storage account's managed identity.

Firewall settings on Key Vault

- **Public network access:** *Enabled from all networks* · *Enabled from selected virtual networks and IP addresses* (service endpoint + IP rules) · **Disabled (private endpoint only).**
- **Allow trusted Microsoft services to bypass this firewall** — lets services like Azure Backup, Disk Encryption, Storage (CMK), Azure Resource Manager templates deployment reach the vault.
- **Private endpoint** (group ID `vault`, DNS zone `privatelink.vaultcore.azure.net`) is the strongest network control.
- IP rules accept **public** IPs/CIDR only (no private ranges).

Manage keys, secrets, and certificates

Topic	What to know
Key types	RSA (2048/3072/4096), EC (P-256/384/521), oct-HSM. HSM-backed = Premium vault or Managed HSM.
BYOK	Import a key generated in your on-prem HSM (key exchange key + wrapped target key) so it never leaves an HSM unprotected.
Key rotation	Set a rotation policy (auto-rotate before expiry, notify via Event Grid NearExpiry). CMK consumers can use <i>automatic key version</i> updates.
Secret rotation	Dual-credential pattern: two valid credentials so rotation causes zero downtime; Event Grid triggers a Function to rotate.
Certificates	Self-signed, integrated CA (DigiCert, GlobalSign), or non-integrated CA (CSR). Lifetime actions: auto-renew at % lifetime or N days before expiry, or email only.
Backup/restore	Per-object backup (same geography/subscription); rely on soft delete + purge protection for recovery.



Defender for Key Vault and secret scanning

- **Microsoft Defender for Key Vault** (a Defender for Cloud plan) detects unusual/suspicious access: access from **Tor/anonymizing IPs**, unusual user/app/location, high-volume operations, suspicious secret listing/enumeration.
- **Defender CSPM agentless secret scanning** finds **plaintext secrets** (keys, tokens, connection strings) on VMs and in cloud deployments and surfaces them as recommendations/attack paths — move them into Key Vault.

Azure CLI — RBAC-enabled, purge-protected vault; least-privilege app access

```
az keyvault create --name kv-sc500 --resource-group rg-sec --location southeastasia \  
  --enable-rbac-authorization true --enable-purge-protection true \  
  --retention-days 90 --public-network-access Disabled  
  
az role assignment create --assignee <app-mi-object-id> \  
  --role "Key Vault Secrets User" --scope <vault-resource-id>
```



1.3 Governance: enforce security and regulatory compliance

Azure Policy

Term	Meaning
Policy definition	Rule in JSON: if (conditions on resource properties/aliases) then effect. Built-in or custom . Mode: All (all resource types) vs Indexed (only types that support tags & location).
Initiative (policy set)	Group of definitions assigned together (e.g. Microsoft cloud security benchmark , CIS, NIST).
Assignment	Definition/initiative + scope (management group → subscription → RG) + exclusions + parameters + enforcement mode (Default vs DoNotEnforce) + a managed identity when the effect remediates.
Exemption	Waiver/mitigated exception for a scope or resource (with expiry) — stays visible in compliance.
Compliance evaluation	On resource create/update, on new assignment, about every 24 hours , or on demand (az policy state trigger-scan).
Remediation task	Fixes existing non-compliant resources for DeployIfNotExists and Modify effects (new resources are handled at deployment).

Effects (memorize the differences)

Effect	Behavior	Notes
Deny	Blocks the create/update request.	Prevention. Does not change existing resources.
Audit	Allows, marks non-compliant (warning event in activity log).	Reporting only.
AuditIfNotExists	Audits when a related resource (e.g. extension, diagnostic setting) is missing.	Reporting on a related resource.
Modify	Adds/updates/removes properties or tags (uses roles in the assignment's managed identity).	Preferred over Append. Supports remediation tasks.
Append	Adds fields to the request at create/update.	Older; mainly for fields on new resources; cannot fix existing ones.
DeployIfNotExists (DINE)	Deploys an ARM template if the related resource is missing.	Needs a managed identity with the right role ; remediation task for existing resources.



Effect	Behavior	Notes
DenyAction	Blocks a specific action (e.g. DELETE) on resources.	Protect from deletion without locks.
Disabled / Manual	Turn off the rule / manual attestation.	

Evaluation order: Disabled → **Append/Modify** → **Deny** → **Audit**; then, after the resource provider returns success, **AuditIfNotExists / DeployIfNotExists**.

Minimal custom policy — deny storage accounts that allow HTTP

```
{
  "if": { "allOf": [
    { "field": "type", "equals": "Microsoft.Storage/storageAccounts" },
    { "field": "Microsoft.Storage/storageAccounts/supportsHttpsTrafficOnly", "equals": "false" }
  ]},
  "then": { "effect": "deny" }
}
```

EXAM TRAP

Audit vs Deny vs DINE: “report only” = **Audit**; “block creation” = **Deny**; “automatically enable diagnostics/agent if missing” = **DeployIfNotExists**.

DINE/Modify **do nothing to existing resources until you run a remediation task**.

Azure Policy governs **resource properties**; **RBAC governs who can act**. A policy cannot grant permission and RBAC cannot force a configuration.

Exclusions vs exemptions: exclusion is part of the assignment (scope carve-out); exemption is a separate object with category (**Waiver/Mitigated**) and optional expiry.

Azure Blueprints is deprecated — use **Policy + template specs / deployment stacks / IaC**.

Defender for Cloud: standards, recommendations, and regulatory compliance

- **Microsoft cloud security benchmark (MCSB)** is the default initiative; it drives **recommendations** and the **Secure Score**.
- **Add standards** (CIS, NIST SP 800-53, PCI DSS, ISO 27001, SOC 2, HIPAA...) under *Environment settings* → *Security policies* → *Standards*; assign at **management group** scope for consistency.
- **Regulatory compliance dashboard:** per standard → controls → assessments; investigate control gaps; **download audit-ready reports**; manual attestation for non-automatable controls.



- **Recommendation actions:** *Fix* (quick-fix / remediation logic), **Enforce/Deny** (Azure Policy effect to prevent new non-compliant resources), **Exempt** (with justification), and **governance rules** (assign **owner + due date**, grace period, email owners; enforce accountability at scale).
- **Custom recommendations/standards** can be created from your own Azure Policy definitions (or KQL-based custom recommendations with Defender CSPM).

MEMORY TRICK / TIP

Recommendation → **Enforce** (Deny) = **prevent**; **Fix** = **remediate existing**; **Governance rule** = **assign owner & due date**; **Exempt** = **accept risk**.

Resource locks

Lock	Effect
CanNotDelete	Authorized users can read and modify, but not delete .
ReadOnly	Authorized users can only read ; blocks modify and delete (effectively Reader on the resource for control-plane writes).

- Locks apply to the **control plane only** (ARM operations), **not data plane**. Applies to **everyone including Owners** — you must remove the lock first.
- Inherited by child resources. Only **Owner** and **User Access Administrator** (or custom role with `Microsoft.Authorization/locks/*`) can manage locks.
- **ReadOnly surprises:** on a storage account it blocks *List Keys* (POST); on App Service it can block certain operations; on a VM it can prevent start/restart changes. **CanNotDelete** is safer for most resources.

RBAC: built-in roles, custom roles, overprivileged access

Role	Can do
Owner	Full access + assign roles .
Contributor	Full resource management, cannot assign roles (but can list keys → data access via keys!).
Reader	View only.
User Access Administrator	Manage role assignments (and locks).
Role Based Access Control Administrator	Assign roles, optionally constrained with ABAC conditions (limit which roles/principals) — least-privilege delegation of role assignment.



Role	Can do
Security Admin / Security Reader (Azure)	Manage/read Defender for Cloud settings & recommendations.

- **Azure roles vs Microsoft Entra roles are separate systems.** Azure roles = ARM resources (scope hierarchy: management group → subscription → resource group → resource). Entra roles = directory objects (users, apps, groups). A Global Administrator has **no Azure role** by default, but can **elevate access** (User Access Administrator at root) via the tenant toggle.
- **Role assignment** = *security principal* + *role definition* + *scope*. **Deny assignments** exist but are created by Azure-managed features (Blueprints, deployment stacks, managed apps), not by users directly.
- **Custom Azure roles:** JSON with `Actions`, `NotActions`, `DataActions`, `NotDataActions`, `AssignableScopes`. Use when no built-in role gives exactly the least privilege needed.
- **Custom Entra roles:** created from a limited set of permissions (e.g. app registrations, enterprise apps), require **Entra ID P1**; scope can be directory-wide or a single object/administrative unit.
- **Administrative units** delegate Entra roles over a subset of users/groups/devices.

Custom Azure role (JSON)

```
{
  "Name": "VM Restarter",
  "IsCustom": true,
  "Description": "Can view and restart VMs only.",
  "Actions": [ "Microsoft.Compute/virtualMachines/read",
    "Microsoft.Compute/virtualMachines/restart/action" ],
  "NotActions": [], "DataActions": [], "NotDataActions": [],
  "AssignableScopes": [ "/subscriptions/<sub-id>/resourceGroups/rg-prod" ]
}
```

Evaluate and remediate overprivileged assignments

- Find them: **Defender CSPM** identity/permission insights and attack paths, **Cloud Security Explorer**, Azure **Access control (IAM)** → **Role assignments**, **PIM** discovery & reviews, **access reviews** (Entra ID Governance) for Azure roles and groups.
- Fix them: replace Owner/Contributor with a **narrower built-in or custom role**, **scope down** (subscription → RG), convert permanent to **PIM eligible**, remove stale/unused principals, use **groups** instead of individuals, run recurring **access reviews**.



EXAM TRAP

“Grant the **minimum** permission so X can do Y” → choose the **narrowest role at the narrowest scope** (e.g. *Storage Blob Data Reader* on one container, *Key Vault Secrets User* on one secret) — not Contributor/Owner. This pattern shows up **constantly** in SC-500.

Azure Backup security features

Feature	What it does
Enhanced soft delete	Deleted backup data retained (default 14 days , up to 180); can be made always-on so it cannot be disabled. Protects against ransomware/malicious delete.
Immutable vault	Prevents deleting recovery points and weakening policies. Unlocked (testing, reversible) vs Locked (irreversible).
Multi-User Authorization (MUA)	Uses a Resource Guard (separate resource, ideally in a different subscription/tenant owned by a security admin). Critical operations (disable soft delete/MUA, delete protection, reduce retention, modify policy) need approval from Resource Guard access (Backup MUA Operator role).
RBAC roles	Backup Contributor (manage all), Backup Operator (run/restore, not delete/modify policy), Backup Reader .
Encryption	Data encrypted at rest with platform keys; optional customer-managed keys (vault identity + Key Vault).
Network	Private endpoints for vault; “Allow trusted Microsoft services” options for storage/Key Vault access.
Alerts & monitoring	Azure Monitor alerts, Backup Center / Azure Business Continuity Center , immutable audit via diagnostics.

EXAM TRAP

Scenario: “A compromised admin could delete backups — prevent this even from someone with Owner rights” → **Resource Guard (MUA) + immutable vault + always-on enhanced soft delete**. RBAC alone is not enough.

Security controls with infrastructure as code (IaC)

- **Shift-left scanning:** **Microsoft Defender for Cloud DevOps security** connects GitHub / Azure DevOps / GitLab; the **Microsoft Security DevOps (MSDO)** action/extension runs analyzers (e.g. **Template Analyzer** for ARM/Bicep, Checkov, Terrascan, Trivy) on IaC and reports misconfigurations in PRs and as recommendations.



- **Policy-as-code:** define Azure Policy in Bicep/Terraform/JSON, deploy through pipelines; **Deny** effects block non-compliant deployments at deployment time.
- Secure IaC patterns: no secrets in templates (use Key Vault references / secure parameters), **What-if** before deploy, **deployment stacks** (deny settings) to protect deployed resources, least-privilege service connections (workload identity federation).
- **Code-to-cloud mapping** (Defender CSPM) links a cloud risk back to the repo/pipeline that created it.

MEMORY TRICK / TIP

IaC scanning tools to name-drop: **Template Analyzer (ARM/Bicep)**, **Checkov/Terrascan (Terraform, etc.)**, **Trivy (containers/IaC)** — all through the **Microsoft Security DevOps** integration.

DOMAIN 2 · 25–30% (largest domain)

Secure storage, databases, and networking

Storage accounts · Azure SQL · NSG/ASG · AVNM · Virtual WAN · VPN · Entra Private Access · Private Link · Azure Firewall · Network Watcher

2.1 Implement security for storage accounts

Authorization options (strongest → weakest)

Method	Notes
Microsoft Entra ID + RBAC	Recommended. Data roles: <i>Storage Blob Data Owner / Contributor / Reader</i> , <i>Storage Queue/Table Data ...</i> , Azure Files: <i>Storage File Data SMB Share Reader / Contributor / Elevated Contributor</i> , and Storage File Data Privileged Reader/Contributor (REST/OAuth access that overrides file ACLs).
User delegation SAS	SAS signed with Entra credentials (via a <i>user delegation key</i> , requires <i>Storage Blob Delegator</i> role). Blob/ADLS only. Best SAS type.
Service SAS	Signed with the account key; one service (blob/file/queue/table). Can be tied to a stored access policy .
Account SAS	Signed with the account key; spans services. Broadest SAS — avoid.
Shared Key (account keys)	Full control of the account. Disable “Allow storage account key access” when possible (enforce with Azure Policy).



Method	Notes
Anonymous public access	Disable “Allow Blob anonymous access” at account level.

EXAM TRAP

Contributor / Storage Account Contributor can List Keys → they can read data with the account key even without a data role. That is why “disable shared key” + Entra-only auth matters.

Stored access policy applies to **service SAS** only (container, share, queue, table). It lets you **revoke or change** expiry/permissions of already-issued SAS without rotating the account key. It does **not** apply to user delegation SAS or account SAS. Max 5 policies per container/share/queue/table.

To revoke a **user delegation SAS**: revoke the user delegation keys or remove the signer’s permissions; to revoke an **account/service SAS** without a policy: regenerate the account key.

Encryption and data protection

- **Encryption at rest**: always on (256-bit AES SSE). Keys = **Microsoft-managed** (default) or **customer-managed (CMK)** in Key Vault/Managed HSM; **infrastructure encryption** adds a 2nd layer. CMK needs **soft delete + purge protection** and a managed identity with *Key Vault Crypto Service Encryption User*.
- **Encryption in transit**: **Secure transfer required** (HTTPS/SMB encryption), **minimum TLS 1.2**.
- **Immutable storage (WORM)**: time-based retention and **legal hold** at container or version level; also blob **versioning**, **soft delete**, **point-in-time restore**.
- **Azure Files identity access**: on-prem AD DS, **Microsoft Entra Domain Services**, or **Microsoft Entra Kerberos** (hybrid identities). Share-level RBAC + NTFS ACLs.

Azure Storage firewall rules

Setting	Behavior
Public network access	<i>Enabled from all networks</i> · <i>Enabled from selected virtual networks and IP addresses</i> (default action = Deny) · Disabled (private endpoint only).
Virtual network rules	Subnets with the Microsoft.Storage service endpoint allowed.
IP network rules	Public IPs / CIDR only. Private ranges (10.x, 172.16.x, 192.168.x) cannot be used.
Resource instance rules	Allow specific resource instances (e.g. an Azure AI service, Synapse) by resource ID + tenant.
Exceptions	Trusted Microsoft services , read access to logging/metrics.
Private endpoints	One per sub-resource: blob, file, queue, table, dfs, web. Use private DNS zones (privatelink.blob.core.windows.net, ...).



Setting	Behavior
Service endpoint policies	Restrict a subnet's service-endpoint traffic to specific storage accounts (stop data exfiltration to other accounts).

EXAM TRAP

IP rules do not apply to requests from the same Azure region as the storage account (traffic uses private Azure IPs).

Use **VNet rules or private endpoints** for same-region Azure workloads.

Firewall rules apply to the **data plane**; management operations use ARM (not blocked by the firewall).

Need **on-premises access without public exposure** → private endpoint over VPN/ExpressRoute (service endpoints do not extend to on-prem).

Lock down a storage account

```
az storage account update -n stsc500 -g rg-sec \
  --default-action Deny --bypass AzureServices \
  --allow-blob-public-access false --allow-shared-key-access false \
  --min-tls-version TLS1_2 --https-only true

az storage account network-rule add -g rg-sec --account-name stsc500 \
  --vnet-name vnet-app --subnet snet-app
```

Microsoft Defender for Storage

Feature	Detail
Activity monitoring	Detects unusual/suspicious access (Tor, anonymous access, unusual locations, mass download/deletion, SAS abuse) on Blob, Files, Data Lake.
Malware scanning (add-on)	Scans blobs on upload using Defender Antivirus; pay-per-GB with a configurable monthly cap ; results as blob index tags ("Malware Scanning scan result") and Defender for Cloud alerts, Event Grid, Log Analytics; supports automated response (e.g. Logic App/Function to quarantine). Blob storage.
Sensitive data threat detection	Alerts enriched with sensitive-data context; identifies exposure of sensitive data.
Scope	Enable per subscription or per storage account (with override); pricing per storage account (plus scan GB).



2.2 Implement security for databases (Azure SQL)

Platform-level security in Azure SQL

Layer	Control
Identity	Microsoft Entra-only authentication (disable SQL auth), Entra admin group, managed identities for apps, contained database users from external provider, MFA for admins.
Network	Server firewall rules (IP), virtual network rules , private endpoint , Deny public network access , minimum TLS 1.2. Avoid <i>Allow Azure services and resources to access this server (0.0.0.0)</i> — too broad.
Encryption at rest	TDE on by default (service-managed key) or CMK/BYOK in Key Vault (needs <i>get</i> , <i>wrapKey</i> , <i>unwrapKey</i> ; purge protection).
Encryption in use	Always Encrypted — client-side, column master key in Key Vault or cert store; server never sees plaintext; optional secure enclaves for richer queries.
Data masking	Dynamic Data Masking — masks query output for non-privileged users; not encryption ; UNMASK permission reveals.
Row-level security	Security policy + predicate function (filter / block predicates) restricting which rows a user sees/writes.
Data discovery & classification	Labels/sensitivity, feeds auditing and Defender.
Ledger	Tamper-evident tables for integrity.
Vulnerability assessment	Part of Defender for SQL: scans, baselines , remediation guidance.

EXAM TRAP

TDE protects data files/backups at rest; it does **not** hide data from a DBA running queries. To hide from DBAs → **Always Encrypted**. To hide from app users in query results → **Dynamic Data Masking**. To limit rows → **Row-Level Security**.

CMK for TDE: if the Key Vault key becomes inaccessible the database becomes **inaccessible** — that is why purge protection + backup of the key matter.

Auditing for Azure SQL Database and SQL Managed Instance

- **Destinations:** Azure **Storage account**, **Log Analytics workspace**, **Event Hubs** (for SIEM). Storage can use **immutable (WORM) blob** for tamper-proof retention.



- **Levels:** **server-level** audit applies to all databases; **database-level** audit for one DB. If both are enabled the database may be audited **twice**.
- **Audit action groups** (defaults): `BATCH_COMPLETED_GROUP`, `SUCCESSFUL_DATABASE_AUTHENTICATION_GROUP`, `FAILED_DATABASE_AUTHENTICATION_GROUP`. Add groups for permission changes, schema changes, etc.
- **Managed Instance:** server-level auditing to Storage/Event Hubs/Log Analytics (via diagnostic settings) or T-SQL `CREATE SERVER AUDIT`; storage access with managed identity or SAS.
- Route logs to **Microsoft Sentinel** via Log Analytics for detection/hunting; retention set on the destination.

Defender for Databases

Plan	Protects
Defender for Azure SQL databases	Azure SQL DB / Managed Instance / Synapse dedicated pool: SQL injection, brute force, anomalous access & queries, vulnerability assessment .
Defender for SQL servers on machines	SQL Server on Azure VM, Arc-enabled, on-prem, AWS/GCP.
Defender for open-source relational databases	PostgreSQL, MySQL, MariaDB (brute-force and anomalous activity).
Defender for Azure Cosmos DB	Anomalous access, injection attempts.

- Enable at **subscription** scope (Defender plans) — can be enforced at scale with **Azure Policy (DeployIfNotExists)**; alerts go to Defender for Cloud / Sentinel.
- Auditing = **evidence & investigation**; Defender = **detection & alerting**. Use both.



2.3 Implement security for Azure network services

Network security groups (NSGs) and application security groups (ASGs)

Topic	Detail
NSG	Stateful allow/deny filter for a subnet and/or NIC . Rules: priority 100–4096 (lower number = evaluated first), source, destination, service/port, protocol, action. First match wins .
Default rules	Inbound: AllowVNetInBound (65000) , AllowAzureLoadBalancerInBound (65001), DenyAllInBound (65500) . Outbound: AllowVnetOutBound (65000), AllowInternetOutBound (65001) , DenyAllOutBound (65500). Cannot delete defaults, but can override with lower-numbered rules.
Order when both attached	Inbound: subnet NSG first → then NIC NSG. Outbound: NIC NSG first → then subnet NSG. Both must allow.
Service tags	Named Microsoft-managed IP groups: Internet, VirtualNetwork, AzureLoadBalancer, Storage, Sql, AzureActiveDirectory, AzureCloud, GatewayManager... (regional variants exist).
ASG	Group VM NICs by role (web, app, db) and use the ASG as source/destination in NSG rules — no IP maintenance. All NICs in an ASG must be in the same VNet .
Flow logs	VNet flow logs are the replacement for NSG flow logs (NSG flow logs are being retired; no new ones can be created). Use with Traffic Analytics .

EXAM TRAP

“VMs in **different subnets** cannot talk although NSG looks fine” → check **both** subnet and NIC NSGs, plus **AVNM security admin rules**, Azure Firewall/UDR.

NSG rule with source = **Internet** and port 3389/22 from **Any** is the classic finding; fix with **Bastion/JIT**.

ASGs simplify rules but they don't cross VNets; NSGs cannot filter by FQDN — use **Azure Firewall** for FQDN.

Azure Virtual Network Manager (AVNM)

- **Scope:** management group(s) and/or subscription(s) — including **cross-tenant** connections. Manage **network groups** at scale.
- **Network groups:** static membership or **dynamic membership** (Azure Policy conditions on tags/names).
- **Configurations:** **connectivity** (hub-and-spoke, mesh, direct connectivity between spokes), **security admin rules**, **routing** configurations. Must be **deployed** (committed) to target regions to take effect.



- **Security admin rules** are evaluated **before NSG rules**: **Deny** (traffic blocked; NSGs cannot override), **Always allow** (allowed, **skips NSG**), **Allow** (allowed but **NSG still evaluated** afterwards). Use to enforce org-wide blocks (e.g. deny 3389/22 from Internet).

MEMORY TRICK / TIP

AVNM security admin rule actions: **Deny** = final block · **Always allow** = final allow (skips NSG) · **Allow** = allow, then NSG decides. NSGs cannot override a Deny from AVNM.

Azure Virtual WAN security

- **Virtual WAN** = managed hub-and-spoke connectivity for branches (site-to-site VPN, **point-to-site**, ExpressRoute, SD-WAN) and VNETs; **Standard SKU** needed for hub-to-hub / VNet-to-VNet transit and firewall.
- **Secured virtual hub** = a Virtual WAN hub with **Azure Firewall** deployed and managed by **Azure Firewall Manager**. Use **routing intent and routing policies** to send **Internet** and/or **private** traffic through the firewall (inspection for branch-to-VNet and VNet-to-VNet).
- Central **Azure Firewall Policy** (parent/child inheritance) applies consistent rules across hubs; **security partner providers** (e.g. Zscaler, Check Point, iboss) can protect internet-bound traffic.
- VPN/P2S in vWAN: use **Entra ID / certificate / RADIUS** auth for user VPN; site VPN with custom IPsec/IKE policies.

VPN connection security

Topic	Detail
Types	Site-to-site (S2S) : IPsec/IKE between gateway and on-prem device. Point-to-site (P2S) : client to gateway. VNet-to-VNet .
P2S protocols	OpenVPN (TLS 443), IKEv2 , SSTP (Windows only).
P2S authentication	Microsoft Entra ID (OpenVPN + Azure VPN Client → supports Conditional Access & MFA), Azure certificates , RADIUS .
Hardening	Route-based VPN, custom IPsec/IKE policy (strong ciphers, PFS), pre-shared keys ≥ 32 chars, BGP , active-active for HA, zone-redundant gateway SKUs, GatewaySubnet NSGs discouraged.
ExpressRoute	Private but not encrypted by default → add MACsec (ExpressRoute Direct) or IPsec VPN over ExpressRoute if encryption is required.



Microsoft Entra Private Access

Part of **Global Secure Access** (Microsoft's Security Service Edge). It provides **Zero Trust Network Access (ZTNA)** to private apps/resources **without a full network VPN**.

- **Components:** **Global Secure Access client** on devices + **Private network connector** installed on a server in the private network (**outbound-only** connections, like Application Proxy) + **connector groups**.
- **Two ways to publish:** **Quick Access** (broad access to IP ranges/FQDNs/DNS suffixes) vs **per-app access** (an enterprise application with **app segments** — FQDN/IP/CIDR + protocol + ports) so you can apply **Conditional Access per application**.
- Enable the **Private access traffic forwarding profile**; configure **Private DNS** so private names resolve through the tunnel.
- Use CA (**MFA, compliant device, authentication strength**) per app — the big advantage over a VPN that grants network-level access.

Private endpoints and Private Link

	Service endpoint	Private endpoint (Private Link)
How it works	Extends VNet identity to a PaaS service; the service keeps its public IP but firewall allows the subnet.	A NIC with a private IP in your subnet mapped to one specific PaaS resource/sub-resource.
On-prem access	Not supported (except special ExpressRoute cases).	Yes via VPN/ExpressRoute + DNS.
Data-exfiltration control	Coarse (service-wide), improved with service endpoint policies .	Best — access to a specific instance only.
DNS	No change.	Requires private DNS zone (e.g. <code>privatelink.blob.core.windows.net</code> , <code>privatelink.database.windows.net</code> , <code>privatelink.vaultcore.azure.net</code>).
Cost	Free.	Per endpoint + data processed.

- **Private endpoint** requires: target resource ID, **group ID (sub-resource)**, subnet, and approval (auto-approve if you own it; **manual approval** otherwise).
- **Network policies for private endpoints** (NSG / UDR support on the subnet) can be enabled so NSGs filter traffic to PEs.
- After creating PEs, **disable public network access** on the PaaS resource, otherwise the public path stays open.



- **DNS is the #1 failure:** the FQDN must resolve to the **private IP**. On-prem clients need a **conditional forwarder** to Azure (via **Azure DNS Private Resolver** or a DNS forwarder in the VNet using 168.63.129.16).
- **Enforce at scale:** Azure Policy — *Deny* public network access, *DeployIfNotExists* private DNS zone groups; Defender for Cloud recommendations.

Private Link service (expose your own service privately)

- A **Private Link service** lets consumers reach **your** service (behind a **Standard Internal Load Balancer**) via **their own private endpoints** — no VNet peering or public exposure.
- Needs **NAT IP configuration** (source NAT, at least one IP), **visibility & auto-approval** settings (by subscription ID), and gets an **alias** consumers can use. **TCP proxy protocol v2** can pass the consumer's source IP.
- Provider side = **Private Link service**; consumer side = **private endpoint**. Do not confuse with **Private Link** (the platform) or private endpoint to Azure PaaS.

Private endpoint for Blob + DNS zone

```
az network private-endpoint create --name pe-blob --resource-group rg-sec \
  --vnet-name vnet-app --subnet subnet-pe \
  --private-connection-resource-id <storage-account-id> \
  --group-id blob --connection-name conn-blob

az network private-dns zone create -g rg-sec -n privatelink.blob.core.windows.net
```

Azure Firewall

SKU	Key features
Basic	SMB scale; threat intel alert; limited throughput.
Standard	L3–L7 filtering, FQDN & network rules , SNAT/DNAT , threat-intelligence-based filtering (alert / alert & deny) , FQDN tags, service tags, DNS proxy, IP Groups.
Premium	Everything in Standard + TLS inspection , IDPS (signature-based intrusion detection/prevention), URL filtering , web categories .

- **Azure Firewall Policy** = the modern rule container: **rule collection groups** → rule collections (priority **100–65000**) → rules. **Parent/child inheritance** for central + local rules; managed centrally via **Firewall Manager**.
- **Processing order:** **DNAT rules** → **Network rules** → **Application rules** (within priority; if a network rule matches, application rules are not evaluated for that traffic).
- **FQDN in network rules** requires **DNS proxy** enabled. **Application rules** handle HTTP/HTTPS/MSSQL by **FQDN/FQDN tags** (e.g. WindowsUpdate) and web categories (Premium).



- **Deployment:** dedicated **AzureFirewallSubnet** (/26); optional **AzureFirewallManagementSubnet** (forced tunneling / Basic). Steer traffic with a **UDR 0.0.0.0/0** → Virtual appliance → firewall private IP.
- **Premium TLS inspection** needs an **intermediate CA certificate** stored in **Key Vault** and a **managed identity** for the firewall.
- **Logging:** structured **resource-specific** logs to Log Analytics; **Azure Firewall Workbook**; Sentinel solution; alerts on threat-intel hits.
- **Availability zones** for resilience; **secured hub** in Virtual WAN for branch inspection.

Need	Use
Allow/deny by IP/port within VNet, cheap, distributed	NSG / ASG
Central FQDN/URL/TLS/IDPS filtering, egress control	Azure Firewall (Premium for TLS/IDPS/URL)
Protect web apps from OWASP attacks (L7 HTTP)	WAF (Application Gateway / Front Door)
Org-wide baseline rules across many VNets	AVNM security admin rules
Volumetric DDoS	DDoS Protection (Network Protection or IP Protection)

Evaluate effective security rules with Network Watcher diagnostics

Tool	Use it to...
IP flow verify	Test whether a specific 5-tuple (protocol, local/remote IP & port, direction) is allowed or denied to/from a VM and which NSG rule decided it.
Effective security rules	See the aggregated, effective NSG rules on a NIC (subnet + NIC combined).
NSG diagnostics	Given traffic details, shows all NSGs evaluated and the matching rules along the path (newer, more complete than IP flow verify).
Next hop	Which route/next hop a VM's traffic uses (find UDR/Firewall/blackhole issues).
Connection troubleshoot / Connection Monitor	End-to-end reachability, latency, hop analysis over time.
Packet capture, VPN diagnostics, Topology	Deep packet analysis, gateway/tunnel health, visualise resources.

EXAM TRAP

“Why is traffic to the VM blocked? Which rule?” → **IP flow verify** (tells the rule) or **NSG diagnostics**. “What rules effectively apply to this NIC?” → **Effective security rules**. “Where is the packet routed?” → **Next hop**.



Related topics that can still appear

DDoS Protection tiers

Tier	Scope & features
Infrastructure protection (default)	Free, platform-level, always on for all Azure public IPs.
DDoS IP Protection	Per public IP billing; adaptive tuning, attack analytics/metrics; no DDoS Rapid Response (DRR), no cost protection, no WAF discount.
DDoS Network Protection	Per VNet (plan can cover many VNets/IPs); adds DRR support , cost protection (credits for scale-out costs), and WAF discount on Application Gateway WAF.

Web front-doors

- **Azure Front Door** (global L7 edge) + **WAF**; **Premium** supports **Private Link origins**; lock backends to your Front Door via the **X-Azure-FDID** header / service tag.
- **Application Gateway** (regional L7 load balancer) with **WAF v2**. See WAF details in Domain 3.



DOMAIN 3 · 20–25%

Secure compute

AI security · Servers & VMs · Containers · Functions · Logic Apps · App Service · WAF · API Management

3.1 Implement security for AI

NEW IN SC-500 (not in AZ-500)

This is the biggest **new** area. Product names and portal experiences here are changing quickly (Purview DSPM, Entra Agent ID, Agent 365, Foundry guardrails). The notes below follow the official skills list and the Microsoft Learn module descriptions; **always cross-check the exact steps in Microsoft Learn / the labs (Lab 3A–3D).**

The big picture: what can go wrong with AI

Risk	Example	Control (SC-500 tool)
Oversharing / data exposure	Copilot surfaces a confidential file because the SharePoint site is shared with “Everyone except external users”.	Purview DSPM data risk assessments, SharePoint access controls, sensitivity labels , DLP
Agent identity abuse	A compromised AI agent uses its permissions to reach data/apps.	Entra Agent ID + Conditional Access, lifecycle/sponsors, Defender XDR blast radius
Prompt injection / jailbreak	User or a document tricks the model or agent into leaking data or misusing tools.	Copilot Studio real-time protection , Foundry guardrails , Defender for AI Services
Uncontrolled model traffic	Apps call models without limits, auth, or logging; token/cost abuse.	AI Gateway (API Management) for Foundry
Shadow agents / AI	Unknown agents and AI apps in the tenant.	Agent 365 / M365 admin center , Purview DSPM, Data and AI security dashboard

Identify overexposure of data in SharePoint

- **Why it matters:** Microsoft 365 Copilot only surfaces content the user **already has permission** to see — so **over-permissioned SharePoint content becomes discoverable through Copilot**. Fix permissions/labels first; do not blame Copilot.



- **Find it:** Purview **DSPM data risk assessments** (default assessment of top sites, plus custom assessments) show sites with sensitive data that is **overshared** (org-wide links, **Everyone except external users**, broad group access, unlabeled sensitive files).
- **Also: SharePoint Advanced Management** reports (data access governance/oversharing reports), site access reviews, sharing-link reports.
- **Fix it:** remove broad sharing, restrict **“Anyone”/org-wide links**, apply **sensitivity labels** (Copilot honours label usage rights), use **restricted content discovery** / **restricted access control** for sensitive sites, and apply **DLP** policies for Copilot interactions.

Purview DSPM: risks from Microsoft Copilot and AI apps

- **Data Security Posture Management (DSPM)** in Microsoft Purview gives a central view of **sensitive data flowing into AI**: Copilot, Copilot Studio agents, Entra-registered AI apps, and third-party generative-AI sites (via browser extension / network data security / Defender for Cloud Apps discovery).
- **Reports & insights:** AI interactions with sensitive info types, unlabeled/unprotected data used by Copilot, risky users (Insider Risk signals), top data risks.
- **One-click / recommended policies:** DLP for AI prompts and responses, Insider Risk (“risky AI usage”), Communication Compliance, retention for AI interactions, auto-labeling.
- **Prerequisites:** **Audit** enabled (AI interactions are captured in the unified audit log), correct **Purview roles** (e.g. Purview Data Security / Compliance admins), browser extension for non-Microsoft AI sites.
- Combines with **Defender for Cloud’s Data and AI security dashboard** (Azure-side AI workloads) — DSPM = **Microsoft 365 / Copilot-side data**, Defender for Cloud = **Azure AI workload-side posture**.

MEMORY TRICK / TIP

Simple split: **Purview DSPM** → “what **data** are people/AI exposing?” · **Defender for Cloud (Data & AI dashboard, Defender for AI Services)** → “how are my **Azure AI workloads** configured and attacked?” · **Entra Agent ID** → “what **identity** does the agent have?”

Real-time protection for Microsoft Copilot Studio agents

- **Microsoft Defender for Cloud Apps runtime protection** evaluates an agent’s **planned actions/tool calls in real time** while the agent runs, and can **block** suspicious ones (e.g. prompt injection/exfiltration attempts) before they execute.
- **Setup (per Learn module):** connect Copilot Studio / **Power Platform** to Defender using an **Entra app registration (Power Platform App ID)**, enable threat detection/runtime protection for the environment(s) in the **Power Platform admin center**, then investigate alerts in the **Defender portal**.



- Combine with Copilot Studio governance: **DLP policies** on connectors, environment strategy, authentication of the agent (Entra ID) and least-privilege connections.

Microsoft Entra Agent ID

Entra Agent ID gives **AI agents first-class identities** in Microsoft Entra so they can be governed like users and apps: authenticated, authorized, monitored, and lifecycle-managed.

- **Concepts:** an **agent identity blueprint** (template/definition) creates **agent identities** (the runtime identities used for tokens). Each agent should have accountable human **owners/sponsors**. Agents can act **autonomously** (as themselves) or **on behalf of a user**.
- **Conditional Access for agents:** apply CA to agent identities — e.g. **block** agents that are **high risk**, restrict which **resources** agents can access, restrict by network location. Same policy engine, agents as the assigned identity type.
- **Manage access:** grant only the API permissions/roles the agent needs (**least privilege**), use **access packages/entitlement management** style governance, **expire/disable** unused agents, review sponsorship and owners, and **revoke** when compromised.
- **Lifecycle:** create → assign owner/sponsor → grant least-privilege access → monitor sign-ins/risk → review → disable/delete when retired (avoid orphaned agents).

Analyze blast radius with Defender XDR

- **Blast radius** = everything an agent (or its identity) could reach if it were compromised: roles, API permissions, data stores, downstream apps.
- In **Microsoft Defender XDR** (exposure management / identity and attack-path views) you **discover AI agents**, review their **permissions and connections**, and analyze **attack paths** to critical assets — then reduce permissions or apply CA to shrink the blast radius.

EXAM TRAP

Agent needs read access to one SharePoint site → grant **scoped, least-privilege permission** (site-level), not tenant-wide `Sites.Read.All/Files.ReadWrite.All`. Large blast radius = wrong answer.

AI Gateway in Azure API Management for Microsoft Foundry

AI Gateway = API Management capabilities specialised for **LLM/AI traffic**: put APIM between apps/agents and **Microsoft Foundry** (Azure OpenAI/model) endpoints to secure, govern and observe model calls.

Capability	How (APIM policy / setting)
Authenticate callers	Subscription keys, <code>validate-jwt</code> / Entra ID (OAuth 2.0) inbound; per-consumer subscriptions.



Capability	How (APIM policy / setting)
Backend authentication	authentication-managed-identity : APIM's managed identity calls Foundry (grant <i>Cognitive Services User</i> / OpenAI User) — no keys in apps.
Token limits / quotas	llm-token-limit per consumer/key (tokens-per-minute, quota) — stop cost abuse & noisy neighbours.
Observability	llm-emit-token-metric (token consumption metrics by dimension), diagnostics to Application Insights/Log Analytics.
Content safety	llm-content-safety — send prompts through Azure AI Content Safety before the model.
Performance & resilience	Semantic caching , load balancing across multiple model backends/regions, circuit breaker .
Lock down the model	Disable Foundry key auth / restrict Foundry network access so it accepts traffic only from APIM (private endpoint / IP allowlist / Entra-only).
MCP / tools	Expose and secure access to MCP servers and agent tools through APIM (OAuth, rate limits).

EXAM TRAP

Central control of **who calls the model, how many tokens, which content filters, and logging** → **APIM AI Gateway**, not just NSGs or Foundry keys distributed to apps.

Defender for AI Services (Cloud Workload Protection)

- Enable the **AI services** plan (AI threat protection) in **Defender for Cloud** → **Environment settings** so **Azure AI services / Foundry** deployments get **runtime threat detection**.
- Typical detections: **jailbreak / prompt-injection attempts** (uses Azure AI Content Safety prompt shields), **sensitive data leakage, credential theft** attempts, **suspicious access patterns** and **denial-of-wallet (token-abuse)** activity.
- Optional **user prompt evidence** adds prompt snippets to alerts — helps investigations but consider **privacy**.
- Alerts flow to Defender for Cloud, Defender XDR and **Microsoft Sentinel**.
- **Posture side (CSPM)**: Defender CSPM discovers AI workloads/resources (AI BOM), flags **misconfigurations** (public network access, key auth) and shows **attack paths**.

Guardrails for agent security in Microsoft Foundry

- **Guardrails** (Foundry's configurable safety/content controls) **evaluate prompts and responses** against risk categories and block or annotate.



- **Risk categories:** hate, sexual, violence, self-harm at configurable **severity thresholds**; **prompt shields** (user prompt attacks & indirect/document attacks); protected material; groundedness — plus **custom blocklists** (terms/patterns).
- **Intervention points:** user **input**, model **output**, and for **agents** also **tool calls / tool responses**, so you can stop an agent from acting on injected instructions.
- **Apply** guardrails to **model deployments and agents**; use stricter policies for agents with tools or sensitive data; test with **red-teaming/evaluations** before production.

Data and AI security dashboard (Defender for Cloud)

- Located in Defender for Cloud (**Data and AI security**). Shows **inventory of AI workloads and data resources**, insights (e.g. internet-exposed AI services, sensitive data on connected stores), **recommendations, attack paths and alerts** for AI workloads.
- Requires the relevant plans — **Defender CSPM** (posture/discovery) and **AI workloads / Defender for AI Services** (runtime) — enabled on the subscription.

Manage agents in the Microsoft 365 admin center (Agent 365)

- **Agent 365** is the **control plane** for agents: a **registry/inventory** of agents across the tenant (Microsoft-built, custom, and partner), **ownership, access controls, lifecycle** (publish, deploy to users/groups, **block/remove**) and **activity monitoring**.
- Integrates with **Entra Agent ID** (identity), **Defender** (security) and **Purview** (data protection).
- Admin tasks: review requested/published agents, assign **owners**, restrict who can create/share agents, **block risky agents**, review permissions.



3.2 Implement security for servers and virtual machines

Disk encryption

Option	What it covers	Notes
SSE with platform-managed keys (default)	Managed disks encrypted at rest on the storage backend.	On by default; does not cover temp disk/cache; no config.
SSE with customer-managed keys (CMK)	Same as above but keys in Key Vault/Managed HSM .	Needs a Disk Encryption Set (DES) ; Key Vault with purge protection .
Encryption at host	Encrypts temp disk and disk caches and flows encrypted to Storage (end-to-end). PMK or CMK.	Preferred modern option; needs the feature enabled/registered and supported VM size; no extension .
Azure Disk Encryption (ADE)	In-guest BitLocker (Windows) / DM-Crypt (Linux) ; keys in Key Vault; encrypts OS + data volumes incl. temp.	VM extension required; on a deprecation path (Microsoft recommends encryption at host) — verify current status. Not supported for Defender agentless scanning .
Confidential disk encryption	Confidential VMs: OS disk bound to VM's vTPM , keys released only to the attested VM.	For Confidential VMs (AMD SEV-SNP / Intel TDX).
Double encryption at rest	Platform key + customer-managed key.	For strict compliance.

EXAM TRAP

“Encrypt **temp disk and cache** too, without an extension” → **encryption at host**.

“Customer controls the key, disk-at-rest” → **CMK via Disk Encryption Set**.

“Data must stay encrypted **in use** (memory) and OS disk bound to VM state” → **Confidential VM + confidential disk encryption**.

Trusted launch security features (secure boot, vTPM, integrity monitoring, security type)

Feature	Purpose
Security type	Standard, Trusted launch, or Confidential . Trusted launch requires Generation 2 VMs (default for new Gen2 in the portal).
Secure Boot	UEFI firmware only boots signed bootloaders/kernel/drivers → blocks rootkits/bootkits .



Feature	Purpose
vTPM	Virtual TPM 2.0 for measured boot (records boot measurements), key storage, BitLocker/attestation, Credential Guard.
Boot integrity monitoring	Uses the Guest Attestation extension + vTPM measurements; Defender for Cloud reports if boot integrity fails (recommendations for missing attestation extension).

Enforce at scale with **Azure Policy** (built-in definitions to require Secure Boot / vTPM / trusted launch on Gen2 VMs).

Azure Bastion

SKU	Highlights
Developer	Free, shared pool, one VM at a time , no dedicated subnet; for dev/test in supported regions.
Basic	Dedicated deployment, RDP/SSH via portal over TLS 443.
Standard	+ native client support (<code>az network bastion ssh/rdp/tunnel</code>), IP-based connection (private IP targets), shareable link , host scaling , custom ports, file transfer.
Premium	+ session recording and private-only deployment (no public IP).

- Needs a subnet named **AzureBastionSubnet** (/26 or larger) and a **Standard SKU static public IP** (except private-only Premium/Developer).
- Target VMs need no public IP**; NSG on the VM subnet must allow **22/3389 from AzureBastionSubnet**.
- Bastion (Basic and above) can reach VMs in **peered VNets**; the Developer SKU cannot.

NSG rules for the AzureBastionSubnet (seen on beta exam reports)

Direction	Rule (source → destination : port)
Inbound	Internet → Any : 443 (client connections) · GatewayManager → Any : 443 (control plane) · AzureLoadBalancer → Any : 443 (health) · VirtualNetwork → VirtualNetwork : 8080, 5701 (host-to-host)
Outbound	Any → VirtualNetwork : 22, 3389 (to target VMs) · Any → AzureCloud : 443 (diagnostic logs / metering) · VirtualNetwork → VirtualNetwork : 8080, 5701 · Any → Internet : 80 (session/cert validation)

Just-in-time (JIT) VM access

- Feature of **Defender for Servers Plan 2** (Defender for Cloud). Closes management ports by default and opens them **only on approved request**.



- **How:** JIT policy per VM defines **ports** (default 22, 3389, 5985, 5986), **max request time** (default 3 h, up to 24 h), **allowed source IPs**. Defender creates **Deny rules** at the top of the **NSG** (or Azure Firewall rules) and on request inserts a temporary **Allow** rule with higher priority.
- **Permissions:** to **request** access → *Microsoft.Security/locations/jitNetworkAccessPolicies/initiate/action* (e.g. Security Admin / custom); to **configure** → *.../jitNetworkAccessPolicies/write*.
- **Enforcement at scale:** Defender recommendation “Management ports should be closed on your VMs” and Azure Policy.
- Works together with **Bastion** (no public IP needed at all) — Bastion removes the need to expose ports; JIT reduces exposure when a port must be open.

EXAM TRAP

Requirements clash: “admins need RDP from **specific IPs for 2 hours only**” → **JIT**. “No public IP on the VM at all” → **Bastion**. Both are acceptable together; choose by what the question stresses.

Azure Arc and hybrid/multicloud servers

- **Azure Arc-enabled servers** project non-Azure servers (on-prem, AWS, GCP) into Azure via the **Azure Connected Machine agent**; the machine gets an ARM resource and a **system-assigned managed identity**.
- **Onboarding at scale:** service principal + script, Group Policy, Configuration Manager, Ansible/Terraform. Roles: **Azure Connected Machine Onboarding**, **Azure Connected Machine Resource Administrator**.
- **Security controls once Arc-enabled:** **Azure Policy & Machine Configuration**, **Defender for Servers**, **Azure Monitor Agent** (→ Sentinel), Update Manager, RBAC, tags.
- **Harden the agent:** restrict extensions with an **allowlist/blocklist** (`azcmagent config`), disable unneeded capabilities (remote access, machine configuration), use **private link scope** so the agent doesn’t talk over the public Internet.
- **AWS/GCP connectors** in Defender for Cloud can **auto-provision Arc** on EC2/GCE VMs for Defender for Servers.

Defender for Servers (Defender for Cloud)

Capability	Plan 1	Plan 2
Microsoft Defender for Endpoint (EDR) integration & auto-onboarding	Yes	Yes
Defender Vulnerability Management (vulnerability assessment)	Yes (core)	Yes (Premium features)
Agentless scanning (vulns, secrets, malware on disk snapshots)	—	Yes (also with Defender CSPM)



Capability	Plan 1	Plan 2
Just-in-time VM access , adaptive network hardening, file integrity monitoring	—	Yes
Free data ingestion allowance to Log Analytics	—	Yes (500 MB/day per machine)

Onboard Azure VMs at **subscription** scope (auto-provisioning) and **Arc/AWS/GCP** servers through Arc/connectors. Exact plan-to-feature mapping changes — verify on Learn before the exam.

Vulnerability scanning and EDR

- **Vulnerability scanning source:** Microsoft **Defender Vulnerability Management** — **agent-based** (MDE sensor) or **agentless**.
- **EDR** = Defender for Endpoint, auto-deployed as the `MDE.Windows` / `MDE.Linux` extension on onboarded machines (Azure VMs and Arc servers).

Agentless scanning

- Takes **snapshots of VM disks** (Azure, and AWS/GCP with connector), analyses them in Microsoft's scanning environment — **no agent, no performance impact**; finds **vulnerabilities, installed software, secrets, (malware)**.
- Enable in **Defender for Servers P2** or **Defender CSPM** settings; supports **exclusion tags**; for **CMK-encrypted** disks grant the scanner access; **ADE-encrypted disks are not supported**.
- Complements — not replaces — agent-based EDR (runtime detection needs the agent).

Azure Machine Configuration

- (Formerly **Guest Configuration**.) Audits and **enforces configuration inside the OS** of Azure VMs and **Arc** machines using Azure Policy definitions.
- **Modes:** **Audit** (report), **ApplyAndMonitor** (apply once, then report drift), **ApplyAndAutoCorrect** (continuously correct).
- **Content:** built-in **Windows/Linux security baselines** (e.g. Azure compute security baseline) or **custom configuration packages** (PowerShell DSC / InSpec-style). Needs the **Machine Configuration extension** and a **managed identity** (assigned by prerequisite DINE policies).
- **Use for:** password policy, registry/service settings, SSH config, missing packages — things Azure Policy cannot see through ARM alone.



MEMORY TRICK / TIP

Azure Policy (ARM properties) vs **Machine Configuration** (settings **inside** the guest OS) vs **Defender for Servers** (threats/vulnerabilities). Pick by *where* the setting lives.



3.3 Implement security for application platform services

Defender for Containers

- Covers **AKS**, **Arc-enabled Kubernetes**, **EKS**, **GKE** and registries (ACR/ECR/GAR).
- **Posture (agentless): agentless discovery for Kubernetes, agentless container vulnerability assessment** (registry and running images; powered by Defender Vulnerability Management), misconfiguration recommendations via the **Azure Policy for Kubernetes** add-on (OPA Gatekeeper).
- **Runtime protection: Defender sensor** (DaemonSet) detects suspicious processes, reverse shells, crypto-mining, drift; **control-plane threat detection** from Kubernetes audit logs.
- **Gated deployment / admission control** to block images with critical vulnerabilities from deploying.
- **ACR image scanning**: on push, on recent pull, and **continuous re-scan**.

Azure Kubernetes Service (AKS)

Area	Controls
Identity & access	AKS-managed Entra ID integration; Azure RBAC for Kubernetes authorization (or Kubernetes RBAC); disable local accounts ; cluster managed identity ; workload identity (OIDC issuer + federated credential + annotated service account) for pods — replaces deprecated pod-managed identity/AAD pod identity.
API server	Private cluster (API server via private endpoint) or authorized IP ranges .
Network	Network policies (Azure NPM, Calico , Cilium) for pod-to-pod east-west; ingress with WAF (App Gateway for Containers / AGIC); egress via Azure Firewall + UDR (outboundType: userDefinedRouting).
Pods	Pod Security Admission with Pod Security Standards (Privileged / Baseline / Restricted) — replaces removed PodSecurityPolicy; Azure Policy add-on for guardrails.
Secrets	Azure Key Vault provider for Secrets Store CSI driver (with workload identity).
Nodes/images	Auto-upgrade channels & node image upgrades , minimal node OS, encryption at host , ACR integration (AcrPull for kubelet identity), Image Cleaner .
Detection	Defender for Containers , audit logs (Kubernetes control plane) to Log Analytics.

AKS hardened baseline (illustrative flags)

```
az aks create -g rg-sec -n aks-sec --enable-aad --enable-azure-rbac \
  --disable-local-accounts --enable-oidc-issuer --enable-workload-identity \
  --enable-private-cluster --network-policy calico --attach-acr acrsc500
```



Azure Container Registry (ACR), ACI, and Container Apps

Service	Security controls
ACR	Premium SKU for private link , geo-replication, CMK, dedicated data endpoints. Disable admin user ; use Entra identities / managed identities with AcrPull (pull) / AcrPush (push) / AcrDelete / AcrImageSigner . Repository-scoped permissions/tokens. Network: firewall rules, private endpoint , disable public access, trusted services. Image signing (Notation/Notary v2 with Key Vault; legacy content trust). Disable anonymous pull. Scan with Defender for Containers.
Azure Container Instances (ACI)	Deploy into a delegated VNet subnet (no public IP), managed identity for ACR pull/Key Vault, secure environment variables (secureValue) & secret volumes, NSG on the subnet; confidential containers option.
Azure Container Apps	VNet-integrated environment (internal vs external), ingress none/internal/external with IP restrictions , built-in authentication (Entra ID), mTLS between apps, managed identity , secrets / Key Vault references , private endpoints, UDR/Firewall egress (workload profiles environments), Dapr access policies.

Azure Functions

- **HTTP trigger authorization levels:** **anonymous** (no key), **function** (function/host key), **admin** (master key). Keys are for basic protection — **not** user identity. For real auth use **App Service Authentication (Easy Auth)** with **Entra ID** and validate claims.
- **Network:** **access restrictions** (inbound IP/service tag/VNet), **private endpoints** (inbound), **VNet integration** (outbound; **Flex Consumption / Premium / Dedicated** — the classic Consumption plan has no VNet integration).
- **Secrets:** **managed identity** + **Key Vault references** in app settings; **identity-based connections** to Storage/Service Bus/Event Hubs instead of connection strings.
- **Hardening:** HTTPS only, minimum TLS 1.2, disable **FTP/basic auth (SCM)**, CORS restrictions, deployment slots.

Azure Logic Apps

- **Inbound access to request triggers:** callback URL contains a **SAS** (regenerate keys), **IP restrictions** for inbound calls, and **OAuth 2.0 authorization policies** (Entra ID; claims validation) — for Consumption you can require OAuth; for **Standard** use **Easy Auth**.
- **Secure inputs/outputs:** turn on **Secure Inputs / Secure Outputs** on triggers/actions so values are **hidden from run history**; use **secure parameters** (securestring/secureobject).
- **Managed identity** for connectors/HTTP actions (system- or user-assigned) instead of stored credentials; secrets in **Key Vault**.



- **Network: Standard** plan (single-tenant) supports **VNet integration** (outbound) and **private endpoints** (inbound); Integration Service Environment (ISE) is retired — use Standard.
- **Run history access:** restrict by IP; use RBAC (*Logic App Contributor/Operator*).

Azure App Service

- **Authentication:** built-in **Easy Auth** (Entra ID etc.), set **Require authentication** (401/redirect for unauthenticated), **managed identity** for back-end access, **Key Vault references**.
- **Network: access restrictions** (separate rules for the **main site** and the **SCM/Kudu** site; IP, service tag, VNet/service endpoint; priority-based), **private endpoint** (inbound), **regional VNet integration** (outbound), **App Service Environment v3** for full isolation.
- **Transport & config:** **HTTPS only**, **min TLS 1.2**, **client certificate** mode, **FTPS only / disable FTP**, disable **basic auth** for FTP/SCM, remote debugging off, CORS, managed certificates.
- **Defender for App Service:** threat detection (suspicious requests, **dangling DNS** subdomain takeover detection).

Azure Web Application Firewall (WAF)

	Application Gateway WAF v2	Azure Front Door WAF
Scope	Regional L7 load balancer (VNet)	Global edge; anycast; Standard/Premium
Managed rules	Default Rule Set (DRS) / OWASP CRS, Bot Manager	DRS, Bot Manager rule set
Custom rules	Match on IP, geo, headers, URI...; Allow/Block/Log; rate limiting	Same + JS challenge / CAPTCHA , rate limiting , geo-filtering, Redirect
Origin lockdown	Public/private frontend	Premium Private Link origins ; restrict origin to AzureFrontDoor.Backend + X-Azure-FDID

- **Modes:** **Detection** (log only) vs **Prevention** (block). Start in Detection, tune, then **Prevention**.
- **Rule order:** **custom rules are evaluated before managed rules**; custom rules are priority-ordered (lower number first; Application Gateway allows 1–100).
- **Anomaly scoring** (CRS 3.x): each matched rule adds to a score (Critical 5, Error 4, Warning 3, Notice 2); request blocked when the score reaches the threshold (5).
- **Exclusions** for false positives (request header/cookie/arg name) — never disable the whole rule set.
- **WAF policy** can be assigned per **gateway / listener / URL path** (App Gateway). Logs to Log Analytics; Sentinel WAF workbook.



Back-end API protection with API Management

Control	Policy / setting
Authenticate callers	Subscription keys (Ocp-Apim-Subscription-Key), validate-jwt / validate-azure-ad-token , OAuth 2.0 authorization server, client certificates (validate-client-certificate, mutual TLS).
Restrict access	ip-filter , product/API scoping, check-header , CORS, VNet integration/injection + private endpoint.
Abuse protection	rate-limit / rate-limit-by-key , quota , request size, validate-content/schema validation.
Back-end authentication	authentication-managed-identity (recommended), authentication-certificate, secrets as named values backed by Key Vault .
Threat detection	Microsoft Defender for APIs (Defender for Cloud plan): inventory APIM APIs, detect unauthenticated/unused APIs, sensitive data exposure, anomalous usage.
AI traffic	AI Gateway policies (see 3.1).



DOMAIN 4 · 20–25%

Manage and monitor security posture

Defender for Cloud (CSPM, multicloud, MDVM, EASM) · Microsoft Sentinel · Microsoft Security Copilot

4.1 Manage security posture with Microsoft Defender for Cloud

Defender for Cloud is Microsoft's **CNAPP**: **CSPM** (posture: find and fix weaknesses) + **CWPP** (workload protection: detect and respond to threats) + **DevOps security**, across **Azure, AWS, GCP and on-prem**.

Defender CSPM: identify security risks

	Foundational CSPM (free)	Defender CSPM (paid plan)
Secure score & recommendations	Yes (MCSB-based)	Yes
Asset inventory, basic regulatory compliance	Yes	Yes (+ more standards)
Attack path analysis	—	Yes
Cloud Security Explorer (graph queries)	—	Yes (incl. multicloud/AWS)
Agentless scanning (vulns, secrets) for VMs/containers	—	Yes
Sensitive data discovery (data-aware posture)	—	Yes
Governance rules, DevOps posture / code-to-cloud mapping	—	Yes
AI workload posture (Data & AI dashboard)	—	Yes

- **Secure score** = % of achieved security controls; each recommendation has **severity** and a **risk level**; prioritise by **attack paths** (a chain such as *internet-exposed VM → high-severity vulnerability → managed identity with storage access → sensitive data*).
- **Cloud Security Explorer**: build queries on the **security graph** (e.g. “VMs exposed to Internet with critical vulnerabilities and permissions to Key Vault”); templates available.
- **Agentless secret scanning** and **identity/permission insights** feed the Domain 1 items (overprivileged access, plaintext secrets).



EXAM TRAP

To use **Cloud Security Explorer / attack paths** (including **AWS/GCP**) you need the **paid Defender CSPM** plan — the free foundational CSPM does **not** provide the graph engine (a beta-exam report specifically tested this).

Evaluate compliance against security frameworks

- Regulatory compliance dashboard: standards (MCSB, CIS, NIST, ISO 27001, PCI DSS, SOC 2, HIPAA, ...) → controls → automated assessments + **manual attestation**.
- Assign standards at the **management group** level; **exempt** with justification; **export reports** (PDF/CSV) for auditors; use **continuous export** to Log Analytics/Event Hubs.

Enable and configure workload protection plans

Plan	Protects
Servers (P1/P2)	VMs and Arc/multicloud servers (EDR, vuln mgmt, JIT, FIM, agentless).
Containers	AKS/EKS/GKE, registries.
Storage	Blob, Files, Data Lake (activity monitoring, malware scanning, sensitive data).
Databases	Azure SQL, SQL on machines, open-source relational DBs, Cosmos DB.
App Service	Web apps (threat detection, dangling DNS).
Key Vault	Suspicious secret/key access.
Resource Manager	Suspicious ARM operations (management-plane threats).
APIs	API Management APIs (Defender for APIs).
AI services	Azure AI / Foundry runtime threats (see Domain 3).

- Enable per **subscription** in *Environment settings* (choose plan tier and extensions); enforce at scale with **Azure Policy** or **Defender for Cloud** built-in **auto-provisioning**.
- Verify **coverage** (Workload protections dashboard) and health of sensors/agents.

Connect hybrid and multicloud (AWS and GCP)

	AWS connector	GCP connector
Scope	Single account or management account (AWS Organizations)	Single project or GCP organization



	AWS connector	GCP connector
Onboarding	CloudFormation template (or Terraform) creating an IAM role trusted through OIDC federation — no long-lived keys	Cloud Shell / Terraform script creating service accounts + workload identity federation
Plans	Choose per connector: CSPM, Servers, Containers, Databases, etc.	Same
Servers	Arc auto-provisioning on EC2 for Defender for Servers	Arc auto-provisioning on GCE
Result	Assets in inventory, recommendations , secure score , attack paths , regulatory compliance for AWS	Same for GCP

- **On-prem servers** connect through **Azure Arc. DevOps** environments (GitHub, Azure DevOps, GitLab) connect through **DevOps security connectors**.
- Use **federated authentication** (no static access keys) and **connector scoping** to control which accounts/projects/regions are covered.

Microsoft Defender Vulnerability Management (MDVM) settings for Azure VMs

- **Scanning methods:** **agent-based** (via MDE sensor) or **agentless** (snapshot). Settings are under *Environment settings* → *Defender for Servers* → *Settings and monitoring / Vulnerability assessment for machines* and choose **Defender Vulnerability Management** as the scanner.
- **Scope:** subscription-level configuration plus **machine-level scoping / exclusion tags**.
- **Plan 2 premium capabilities:** security baselines assessment, browser extension and certificate inventory, network share analysis, hardware/firmware assessment, **authenticated scans**, block vulnerable applications.
- Findings appear as recommendations (“Machines should have vulnerability findings resolved”) with **CVE**, exploitability and remediation guidance.

Microsoft Defender External Attack Surface Management (EASM)

- **Outside-in discovery** of your **internet-facing assets** starting from **seeds** (domains, IP blocks, hosts, contacts/WHOIS, ASNs, organization names) organised into **discovery groups**.
- **Inventory asset types:** domains, hosts, pages, IP addresses, IP blocks, ASNs, SSL certificates, WHOIS contacts.
- **Asset states:** **Approved Inventory, Candidate, Dependency, Monitor Only, Requires Investigation**. Assets can be labelled, given an **external ID**, and observations (e.g. CVEs) can be marked **non-applicable**. Removing a **seed** can also remove assets discovered through it.
- **Dashboards:** attack surface summary, security posture, GDPR, OWASP Top 10, CISA KEV, etc.; findings by **priority (High/Medium/Low)**.



- **Integration:** EASM data feeds **Defender CSPM** to add internet-exposure context. A beta-exam report mentioned a scenario about an **expired asset to hide/remove from inventory** — review “Modifying inventory assets” in Learn.



4.2 Implement activity and event collection in Microsoft Sentinel

Microsoft Sentinel = cloud-native **SIEM + SOAR**. It runs on a **Log Analytics workspace** and is increasingly managed in the **Microsoft Defender portal** (unified security operations); the Azure-portal Sentinel experience is on a retirement path — verify current dates.

Workspaces and roles

- **Create a workspace** (Log Analytics) then **add Microsoft Sentinel** to it. **Design**: a **single workspace** is simplest; use **multiple workspaces** for data sovereignty/region, different ownership/RBAC, or separate billing/retention.
- **Access model**: workspace-context vs **resource-context RBAC**; **table-level RBAC** for finer control.

Sentinel role	Purpose
Microsoft Sentinel Reader	View data, incidents, workbooks — no changes.
Microsoft Sentinel Responder	Reader + manage incidents (assign, change status, comment).
Microsoft Sentinel Contributor	Responder + create/edit workbooks, analytics rules, connectors, etc.
Microsoft Sentinel Automation Contributor	Granted to the Sentinel service so automation rules can run playbooks (assign on the playbook's resource group).
Microsoft Sentinel Playbook Operator	Run playbooks manually.
Logic App Contributor	Create/edit the Logic Apps used as playbooks.

EXAM TRAP

B2B guest users who must **assign incidents** need **Directory Reader** (Entra role) and **Microsoft Sentinel Responder** — both (beta-exam report).

Content hub

- **Solutions** = packaged content: data connectors, analytics rules, workbooks, hunting queries, playbooks, parsers. Install, **update**, and manage from the **Content hub**; standalone content is also available.
- **Repositories** connect Sentinel to GitHub/Azure DevOps for **CI/CD of detections as code**.



Data connectors: Microsoft services and Azure resources

Connector type	Examples & notes
Service-to-service (API)	Microsoft Entra ID, Azure Activity, Microsoft Defender XDR , Microsoft 365, Defender for Cloud (tenant/subscription-based alerts).
Diagnostic settings	Azure resources (Key Vault, NSG, Firewall, Storage, SQL...) → Log Analytics ; roll out at scale with Azure Policy (DeployIfNotExists).
Azure Monitor Agent (AMA) + DCR	Windows Security Events, Windows Forwarded Events, Syslog , CEF .
Codeless Connector Framework / API	Custom SaaS/partner data (Logs Ingestion API + DCR).

EXAM TRAP

The **Log Analytics agent (MMA)** is retired (Aug 2024). New collection = **Azure Monitor Agent + Data Collection Rules**. “Legacy” Security Events / Windows Forwarded Events connectors are the old agent-based versions.

Syslog and Common Event Format (CEF)

- **Linux forwarder** (VM/on-prem) with **AMA**; the device/appliance sends **Syslog or CEF** to the forwarder (rsyslog/syslog-ng → AMA); a **DCR** defines facilities and severities collected.
- **Tables**: Syslog → **Syslog**; CEF → **CommonSecurityLog**.
- Non-Azure machines need **Azure Arc** to run AMA and use managed identity.
- **Filter at the source** (facility/severity selection) and with **ingestion-time transformations** to control cost.

Windows Security events, DCRs, and Windows Event Forwarding (WEF)

- **Windows Security Events via AMA**: choose **All**, **Common**, **Minimal**, or **Custom** (XPath queries) event sets in the DCR. Table: **SecurityEvent**.
- **Windows Forwarded Events (WEF)**: install **AMA on the Windows Event Collector (WEC) server** and use the **Windows Forwarded Events** connector with a DCR that reads the **ForwardedEvents** log. Use WEF when you can't install an agent on every endpoint or want to centralise via GPO-configured forwarding.
- **Choosing**: AMA on each machine = fewer moving parts and rich filtering; **WEF** = aggregation from many endpoints without agents.
- **Sysmon** and other logs: use the Windows Events connector with custom XPath.
- **DCR transformations** (KQL, **source | where ...**) reduce noise and cost **before ingestion**.



KQL examples

```
// DCR ingestion-time transformation: drop noisy events
source | where EventID !in (5145, 5156, 5158)
```

```
// Hunt: failed sign-ins by account in the last hour
SecurityEvent
| where TimeGenerated > ago(1h) and EventID == 4625
| summarize Attempts = count() by Account, IPAddress
| order by Attempts desc
```

```
// CEF: top denied sources
CommonSecurityLog
| where DeviceAction == "Deny"
| summarize count() by SourceIP | top 10 by count_
```

Custom log tables, retention, and data lake

- **Custom tables** end with **_CL**. Create DCR-based custom tables (portal *Tables* → *New custom log*, **Logs Ingestion API**, AMA text/JSON logs) — needs a **DCE** for Logs Ingestion API and Private Link scenarios.
- **Table plans:** **Analytics** (full KQL, alerting, default) · **Basic** (low-cost, limited KQL, short interactive retention) · **Auxiliary** (very low-cost, long-term). Route verbose logs to Basic/Auxiliary.
- **Retention: interactive (hot)** retention (Sentinel workspaces default longer than Log Analytics' 30 days) + **long-term/archive** retention up to **12 years total**; **search jobs** and **restore** to query archived data.
- **Sentinel data lake** is the newer low-cost, long-retention tier for large security data sets — know that it exists and why (cost-efficient retention/analytics).

Automation rules and playbooks

	Automation rule	Playbook
What	Lightweight, built-in rules on incident/alert triggers: change status/severity, assign owner, add tags/tasks, close noisy incidents, run a playbook.	Logic Apps workflow for complex orchestration (block user, isolate device, notify Teams, enrich).
Trigger	Incident created / updated , alert created ; conditions; ordered; optional expiration.	Sentinel incident, alert, or entity trigger; can also run manually .
Permissions	Sentinel needs Automation Contributor on the playbook RG to run playbooks.	Playbook's managed identity needs Sentinel Responder (to update incidents) and rights on target systems.



Query Microsoft Purview Audit in Defender XDR

- **Microsoft Purview Audit** records user/admin activity across Microsoft 365 (and AI/Copilot interactions). In the **Defender portal** you can **search the audit log** (Audit page) and correlate with incidents; the audit data also reaches Sentinel via the Microsoft 365 connector / Defender XDR integration.
- Need **auditing turned on** and the right role (e.g. **Audit Logs / View-Only Audit Logs**). **Audit (Standard)** default retention is **180 days**; **Audit (Premium)** retains longer (1 year default; longer with add-on).
- Use it for: investigating consent grants, mailbox access, file sharing, Copilot/agent activity, admin changes.



4.3 Implement Microsoft Security Copilot

NEW IN SC-500 (not in AZ-500)

Beta-exam feedback said **Security Copilot appeared more than expected** — including **permissions/roles** and the **Sentinel plugin**. Do not skip this section.

What it is

- **Generative-AI security assistant:** natural-language prompts over Microsoft security data (Defender XDR, Sentinel, Entra, Intune, Purview, Defender for Cloud, Threat Intelligence) to **investigate, summarise, and act**.
- **Two experiences:** **standalone** portal and **embedded** in Defender/Purview/Entra/Intune/Sentinel.
- **Effective prompt** has four elements: **Goal · Context · Expectations · Source**. **Promptbooks** = saved multi-step prompt sequences; **pinboards** save findings.

Configure workspaces (capacity, SCUs, data residency)

- **Security Compute Units (SCUs)** = the unit of capacity/billing. You **provision capacity** as an **Azure resource** (subscription + resource group) and choose the **geography (data residency/storage location)**. Overage SCUs can auto-provision.
- A **workspace** is attached to a capacity; organise workspaces by team/region/data boundary. **Workspace-level settings** control plugins and access.
- **Data sharing/privacy settings:** whether Microsoft may use captured data to improve/validate the product; prompts and responses are **not used to train foundation models**.

Permissions and roles

Layer	How it works
Security Copilot roles	Copilot owner (manage capacity/settings/plugins, all data) and Copilot contributor (use Copilot, manage own sessions). Assigned to Entra security groups/users .
Underlying data access	Copilot uses the user's own permissions in each product — a user without Sentinel/Defender access cannot see that data through Copilot (least privilege preserved ; “on-behalf-of”).
Sentinel plugin	User needs Sentinel Reader (or higher) on the workspace to query it via Copilot.
Defaults	Entra roles such as Global Administrator and Security Administrator get owner-level rights by default; others receive contributor via group/role mapping.



EXAM TRAP

“Analysts can use Security Copilot but shouldn’t see Sentinel data they lack access to” → Copilot **respects underlying RBAC**; give **Copilot contributor** + the normal **Sentinel** role only where needed.

Plugins

- **Microsoft plugins** (Defender XDR, Sentinel, Entra, Intune, Purview, Defender Threat Intelligence, Defender for Cloud...) and **non-Microsoft** (ServiceNow, CrowdStrike, etc.) and **custom plugins** (KQL, API/OpenAPI, GPT skills).
- **Governance:** owners control **who can add/enable** plugins (workspace-level vs user-level) and whether **custom/non-Microsoft plugins** are allowed. Enable only what the SOC needs.
- **Sentinel plugin** lets Copilot run KQL/summarise incidents from selected workspaces.

Agents: Microsoft agents and Security Store agents

- **Agents** are autonomous, task-focused AI workers (e.g. **phishing triage, alert triage for DLP/Insider Risk, Conditional Access optimization, vulnerability remediation, threat-intelligence briefing**).
- **Microsoft agents** are built and supported by Microsoft; **Security Store agents** are **partner-built** agents from the **Microsoft Security Store**.
- **Enable and configure:** turn on in the Copilot **agent/Manage** experience, assign the **required permissions/roles** for the agent’s identity, set data/plugin access, monitor **agent runs and outcomes**, and apply **Entra Agent ID** governance.
- Treat agents like privileged automation: **least privilege**, review, and audit.



PART 5

Cheat sheets & final revision

Scenario → answer map · least-privilege role picker · numbers · top traps · final-week plan · resources

5.1 Scenario → best answer map

If the question says...	Think / choose...
Admins should have privileges only when needed, with approval	PIM eligible assignments + approval + MFA on activation
Block risky sign-ins / require device compliance / force MFA for a group	Conditional Access (report-only first)
Users granting broad Graph permissions to unknown apps	Restrict user consent (verified publishers, low-impact), admin consent workflow , revoke grants
App must access Azure resources without secrets	Managed identity (user-assigned if shared) + RBAC
Many resources must share one identity	User-assigned managed identity
Keep secrets/keys/certs safe; block deletion	Key Vault with soft delete + purge protection , RBAC, private endpoint
Customer-managed keys for storage/disks/TDE	Key Vault/Managed HSM + purge protection + managed identity (<i>Crypto Service Encryption User</i>)
Automatically enable diagnostics/agent on new resources	Azure Policy DeployIfNotExists (+ remediation task for existing)
Prevent creation of non-compliant resources	Azure Policy Deny
Report non-compliance only	Azure Policy Audit / AuditIfNotExists
Prevent accidental deletion	CanNotDelete lock (or Policy DenyAction)
Nobody with Owner can delete backups	Resource Guard (MUA) + immutable vault + enhanced soft delete
Revoke an already-issued SAS without regenerating keys	Stored access policy (service SAS)
Best SAS type	User delegation SAS (Entra-signed)
Storage reachable only from the VNet and on-prem, no Internet	Private endpoint + disable public network access
Hide column data from DBAs	Always Encrypted



If the question says...	Think / choose...
Mask output for non-privileged users	Dynamic Data Masking
Users see only their own rows	Row-Level Security
Investigate who ran what on SQL	SQL auditing (Storage/Log Analytics/Event Hubs)
Detect SQL injection / brute force	Defender for Databases (Defender for SQL)
Group VMs by role in NSG rules	ASG
Org-wide rule NSGs cannot override	AVNM security admin rule (Deny)
Central inspection of branch traffic in vWAN	Secured virtual hub (Azure Firewall + routing intent)
TLS inspection / IDPS / URL filtering	Azure Firewall Premium
Find which NSG rule blocked a packet	Network Watcher IP flow verify / NSG diagnostics
Per-app private access instead of VPN	Entra Private Access (per-app + CA)
Expose my service privately to other tenants	Private Link service behind Standard ILB
RDP/SSH to VMs without public IP	Azure Bastion
Open RDP for 2 hours from my IP only	JIT VM access (Defender for Servers P2)
Encrypt temp disk + cache, no extension	Encryption at host
Detect rootkit/boot tampering	Trusted launch : Secure Boot + vTPM + boot integrity monitoring
Enforce OS-level settings (baselines) on VMs/Arc servers	Azure Machine Configuration
Scan VMs without installing an agent	Agentless scanning (Defender for Servers P2 / CSPM)
Protect containers: image vulns + runtime + admission	Defender for Containers
Restrict pod-to-pod traffic in AKS	Network policies (Calico/Cilium/Azure NPM)
Pods access Azure resources without secrets in AKS	Workload identity
Block OWASP attacks on web apps	WAF (App Gateway / Front Door) in Prevention mode
Validate JWT, rate-limit, protect a backend API	API Management policies (validate-jwt, rate-limit, ip-filter)
Central token limits/content safety for LLM calls	APIM AI Gateway for Foundry
Copilot exposing overshared SharePoint content	Purview DSPM risk assessment + fix sharing/labels
Stop an agent acting on injected instructions in Copilot Studio	Real-time protection (Defender for Cloud Apps runtime)
Restrict what an AI agent identity can reach	Entra Agent ID + CA + least privilege ; check blast radius in Defender XDR



If the question says...	Think / choose...
Detect jailbreaks against Azure AI services	Defender for AI Services
Prioritise risk chains across cloud	Defender CSPM attack paths / Cloud Security Explorer
Onboard AWS/GCP	Connector (OIDC federation) + choose plans
Find unknown internet-facing assets	Defender EASM
Collect Windows events from many servers via forwarding	WEF + AMA on the collector (Windows Forwarded Events + DCR)
Reduce Sentinel ingestion cost	DCR transformations , Basic/Auxiliary tables, filter at source
Auto-close noisy incidents / assign owner	Automation rule
Multi-step response (isolate device, notify)	Playbook (Logic Apps)



5.2 Least-privilege role picker

Task	Role / permission
App reads secrets from Key Vault (RBAC model)	Key Vault Secrets User
Create/rotate secrets	Key Vault Secrets Officer
Sign/decrypt/wrap with keys	Key Vault Crypto User
Storage/disk/SQL uses CMK	Key Vault Crypto Service Encryption User (to the resource's managed identity)
Manage vault settings but not data	Key Vault Contributor
Read blob data	Storage Blob Data Reader
Write blob data	Storage Blob Data Contributor
Create a user delegation key (for user delegation SAS)	Storage Blob Delegator
Read Azure Files share (SMB, Entra identity)	Storage File Data SMB Share Reader
Read files ignoring ACLs via REST/OAuth	Storage File Data Privileged Reader
Assign Azure roles	User Access Administrator or RBAC Administrator (conditions restrict which roles)
Manage/read Defender for Cloud	Security Admin / Security Reader
Request JIT VM access	Permission <code>.../jitNetworkAccessPolicies/initiate/action</code> (custom role or Security Admin) — not Reader
Onboard Arc servers	Azure Connected Machine Onboarding
Pull / push images in ACR	AcrPull / AcrPush
Sentinel: triage incidents / author content	Sentinel Responder / Sentinel Contributor
Sentinel: run playbooks from automation rules	Sentinel Automation Contributor (Sentinel service on playbook RG)
B2B guest assigns incidents	Directory Reader + Sentinel Responder
Backup: operate but not delete/modify policy	Backup Operator
Backup: approve critical ops via MUA	Backup MUA Operator on the Resource Guard
Manage Conditional Access	Conditional Access Administrator
Manage authentication methods policy	Authentication Policy Administrator
Manage enterprise apps / app registrations	Application / Cloud Application Administrator



Task	Role / permission
Grant tenant-wide admin consent (incl. Graph app roles)	Global Administrator / Privileged Role Administrator
Use Security Copilot / administer it	Copilot contributor / Copilot owner

5.3 Numbers and defaults to memorise

Item	Value
Exam	700/1000 to pass · 120 min · weights 20–25 / 25–30 / 20–25 / 20–25
NSG rule priority	100–4096 (lower = first) · defaults 65000 / 65001 / 65500
Subnets	AzureBastionSubnet /26+ · AzureFirewallSubnet /26 · AzureFirewallManagementSubnet /26 · GatewaySubnet (VPN) /27 or larger recommended
Firewall rule priorities	100–65000 ; order DNAT → Network → Application
Key Vault	Soft delete 7–90 days · purge protection irreversible · secret max 25 KB
PIM	Default activation max 8 h (configurable)
JIT	Default ports 22, 3389, 5985, 5986 · default 3 h , max 24 h
Stored access policies	Max 5 per container/share/queue/table
Azure Backup enhanced soft delete	Default 14 days (up to 180)
Purview Audit (Standard) retention	180 days
Policy compliance scan	Roughly every 24 h or on demand
WAF anomaly scoring	Critical 5 · Error 4 · Warning 3 · Notice 2 · block at 5
Sentinel/Log Analytics total retention	Up to 12 years (interactive + long-term)
Storage TLS / secure transfer	TLS 1.2 min · HTTPS only



5.4 Top exam traps (read these the night before)

- **Least privilege beats convenience.** Owner/Contributor is almost never the right answer; choose the narrowest data-plane role at the narrowest scope.
- **Contributor can List Keys** on Storage → can read data. Disable shared-key access and use Entra authorization.
- **Key Vault Contributor ≠ secret access** (control plane vs data plane).
- **DINE/Modify need a managed identity (with roles) and a remediation task** for existing resources.
- **Audit ≠ Deny ≠ DeployIfNotExists**; policy = resource properties, RBAC = who can act.
- **Locks are control-plane only** and apply to Owners too; **ReadOnly** can break things (e.g. list keys).
- **PIM** reduces standing privilege; **CA** governs sign-in conditions; use **authentication context** to add strength to PIM activation.
- **Report-only** before enforcing risky Conditional Access policies; keep **break-glass** accounts excluded and monitored.
- **Delegated vs application permissions** — application = admin consent only, very powerful.
- **Stored access policy** = service SAS only; **user delegation SAS** is the safest SAS.
- **Storage IP rules** ignore same-region traffic and cannot use private IPs; use VNet rules / private endpoints.
- **Service endpoints don't work from on-prem**; private endpoints do (with DNS!). Disable public access after creating PEs.
- **TDE ≠ Always Encrypted ≠ Dynamic Data Masking ≠ RLS** — know what each hides and from whom.
- **AVNM Deny cannot be overridden by NSG**; **Allow** still hits NSG; **Always allow** skips NSG.
- **NSG evaluation order**: inbound subnet→NIC; outbound NIC→subnet.
- **Firewall order**: DNAT → Network → Application; FQDN in network rules needs **DNS proxy**.
- **Premium Azure Firewall** = TLS inspection, IDPS, URL filtering (Standard doesn't).
- **Bastion** = no public IP on VM; **JIT** = time-boxed open ports (Defender for Servers **P2**).
- **Encryption at host** covers temp disk & cache; ADE needs an extension and is on a deprecation path.
- **Agentless scanning** doesn't support ADE-encrypted disks and doesn't replace EDR.
- **Machine Configuration** = inside-the-OS settings; Azure Policy alone can't see them.
- **Defender CSPM (paid)** needed for attack paths and Cloud Security Explorer (incl. AWS/GCP).
- **Defender for Storage malware scanning** is on-upload, pay-per-GB, results as blob index tags.
- **AMA + DCR** replaced MMA; **WEF** needs AMA on the collector; **DCR transformations** cut cost.
- **Automation rule vs playbook**; Sentinel needs **Automation Contributor** to run playbooks.
- **Guest users assigning incidents** need **Directory Reader + Sentinel Responder**.



- **Security Copilot honours the user's own RBAC**; SCUs are provisioned as an Azure resource; roles = owner/contributor.
- **Copilot oversharing** is a **permissions/labels** problem in SharePoint — fix the data exposure, not the AI.
- **AI agent least privilege**: scoped permissions, Agent ID + CA, small **blast radius**.
- **AI Gateway (APIM)** = central auth, token limits, content safety, logging for model calls; Foundry **guardrails** = content/prompt safety controls on the model/agent.
- **Read every paragraph twice**: one changed word (“minimum administrative effort”, “without public IP”, “cross-tenant”) flips the answer.

5.5 Final-week plan (7 days)

Day	Focus	Do
1	Domain 1 — Entra	Re-read PIM/CA/consent/managed identity. Lab 1A (PIM) + 1B (CA MFA). Draw the CA policy evaluation flow.
2	Domain 1 — Key Vault, Policy, RBAC, Backup	Lab 1C, 1D. Write your own Policy JSON (Deny) and a custom role. Review Resource Guard/MUA.
3	Domain 2 — Networking (heaviest area)	NSG/ASG/AVNM/Firewall/vWAN/PE/PLS/VPN/Entra Private Access. Lab 2C. Redo the tables in 5.1 from memory.
4	Domain 2 — Storage & SQL	Lab 2A, 2B. SAS types, stored access policy, firewall gotchas, SQL protection layers, auditing.
5	Domain 3 — AI + compute	Labs 3A–3D (DSPM, Agent ID, Foundry/AI Gateway, Defender for AI). Bastion NSG rules, JIT, Arc, Machine Configuration.
6	Domain 3/4 — App platform, Defender for Cloud, Sentinel, Security Copilot	Labs 4B–4F. WAF, APIM policies, AKS/ACR, CSPM/attack paths, AMA/WEF/DCR, automation, Copilot roles/plugins.
7	Consolidate	Only Part 5. Do the exam sandbox, timed scenario practice (≈2 min/question), review weak spots, sleep early.

MEMORY TRICK / TIP

Exam-day tactics: 120 min for ~55–60 questions → **first pass ≈ 1.5 min/question**, **flag** long case-study items, return with the remaining time. Case studies with True/False items reward careful reading of the **requirements list**. Use Microsoft Learn only for a specific detail you truly need.



5.6 Verify these before exam day

These are the areas where product names, plans or portal behaviour change quickly, or where my notes rely on secondary reports. Confirm on Microsoft Learn / the labs:

- Exact **Defender for Servers Plan 1 vs Plan 2** feature table (Learn: *Plan your Defender for Servers deployment*).
- **Entra Agent ID** terminology and the Conditional-Access-for-agents configuration screens (Lab 3B).
- **Copilot Studio real-time protection** setup steps and prerequisites (Learning Path 7 module).
- **Purview DSPM** UI naming (DSPM vs DSPM for AI consolidation) and SharePoint Advanced Management features (Lab 3A).
- **Sentinel in the Defender portal**: dates for the Azure-portal retirement; **Sentinel data lake** availability.
- **Azure Disk Encryption** retirement date; NSG flow logs → VNet flow logs timeline.
- **Security Copilot** role defaults and agent setup screens (Lab 4F).
- Whether the **practice assessment** is published, and whether **labs/performance tasks** have been added to the live exam.

5.7 Resources and labs

Resource	Where
Official study guide (source of truth)	learn.microsoft.com → <i>Study guide for Exam SC-500</i>
Exam & certification page, sandbox, practice assessment	learn.microsoft.com → <i>Microsoft Certified: Cloud and AI Security Engineer Associate</i>
Instructor-led / self-paced course	SC-500T00 — 12 learning paths, 63 modules (intermediate)
Official hands-on labs (Labs 1A–4F)	GitHub: MicrosoftLearning/mslearn-sec-identity
Community companion repo (objectives map, demo scripts, study plan)	GitHub: timothywarner-org/sc500
Community study guide with beta-exam feedback	charbelnemnom.com → <i>Exam SC-500 Study Guide</i>
Free practice environment	Azure free account, Microsoft Learn sandboxes, short trials for Defender plans / Sentinel / Security Copilot (turn off afterwards to avoid charges)



Learning paths in SC-500T00 (by domain)

Domain	Learning paths
1	Secure access with Entra · Key Vault defense in depth · Security governance & compliance
2	Azure Storage security · Azure SQL security · Network security controls
3	Implement security for AI (9 modules) · Servers & VMs (7) · Application platform services (6)
4	Manage security posture with Defender for Cloud · Sentinel activity & event collection (8) · Deploy & operate Security Copilot

Good luck. Keep the mantra: **least privilege · reduce exposure · protect secrets · secure workloads · monitor posture · automate response.**

